SAST/DAST Security Scan Report -- Sprint 42

Meridian Capital

Prepared for Enterprise Risk Steering and Engineering Leadership. This document summarizes the static (SAST via Semgrep) and dynamic (DAST via internal harness) application security scan activities completed during Sprint 42. All analysis was performed against non-production branches and environments. No exploitable conditions were identified during this period; all SAST observations are informational in nature and reflect code quality, convention adherence, and rule calibration outcomes. DAST coverage focused on authenticated and unauthenticated surface validation, latency benchmarking, and schema consistency checks. The following tables provide document control details, execution metadata for CI pipelines, and rule pack inventory utilized in the scans.

Document Control and Metadata

Field	Value
Document Title	SAST/DAST Security Scan Report -- Sprint 42
Organization	Meridian Capital
Business Unit	Technology Risk & Cybersecurity
Prepared By	AppSec Engineering (Team: MC-SEC-APP)
Reviewers	Platform QA (MC-QA-PLAT), Digital Channels Security (MC-SEC..
Version	1.0
Classification	Internal Use Only
Reporting Window	2026-07-08T00:00:00Z to 2026-07-22T23:59:59Z
Generation Timestamp	2026-07-23T08:16:37Z (UTC)
Change Control Ticket	SEC-14231
Related Release Train	2026.07 (RT-2026-07)
Tooling	Semgrep 1.77.0; DAST Harness 3.9.2
Source Control Systems	GitHub Enterprise (GHE-MC01), Bitbucket DC (BB-MC02)
Reference Baselines	Sprint 40 (SEC-14091), Sprint 41 (SEC-14162)
Contact	appsec@meridian-capital.example

SAST/DAST Scan Execution Summary

Pipeline ID	Repository	Branch	Commit SHA	Trigger	Start (UTC)	End (UTC)	Duration Tooling ..
CI-20260717-0945..	core-banking-api	release/2026.07	4c9a1f7	Scheduled	2026-07-17T09:45:..	2026-07-17T09:56:..	11m32s SAST-Std..
CI-20260717-1022..	digital-web-portal	develop	a1e3b22	PR #842	2026-07-17T10:22:..	2026-07-17T10:34:..	12m19s SAST-Std..
CI-20260718-0830..	payments-gateway	release/2026.07	7b2f0cd	Scheduled	2026-07-18T08:30:..	2026-07-18T08:43:..	13m14s SAST-Std..
CI-20260718-1115..	mobile-ios	develop	c44de91	PR #1294	2026-07-18T11:15:..	2026-07-18T11:24:..	9m22s SAST-iOS ..
CI-20260718-1412..	mobile-android	develop	92b1a0e	PR #1632	2026-07-18T14:12:..	2026-07-18T14:26:..	14m54s SAST-An..
CI-20260719-0744..	risk-analytics-svc	feature/ledger-rollup	1f0e0f1	Manual	2026-07-19T07:44:..	2026-07-19T07:54:..	10m07s SAST-Std..
CI-20260719-1230..	data-services	release/2026.07	5a11b9a	Scheduled	2026-07-19T12:30:..	2026-07-19T12:43:..	13m06s SAST-Std..
CI-20260720-0900..	wealth-mobile	release/2026.07	f8c31bb	Scheduled	2026-07-20T09:00:..	2026-07-20T09:13:..	12m54s SAST-An..
CI-20260720-1517..	treasury-workbench	develop	0d7a6ce	PR #458	2026-07-20T15:17:..	2026-07-20T15:28:..	10m28s SAST-Std..
CI-20260721-1011..	aml-monitor	hotfix/ingest-tuning	3a0e3fa	Manual	2026-07-21T10:11:..	2026-07-21T10:22:..	10m31s SAST-Std..
CI-20260721-1645..	partner-integration-..	release/2026.07	6bc4a92	Scheduled	2026-07-21T16:45:..	2026-07-21T17:00:..	14m53s SAST-Std..
CI-20260722-0819..	fraud-detection-ui	develop	1d2c4b8	PR #271	2026-07-22T08:19:..	2026-07-22T08:31:..	11m31s SAST-TS/..

Rule Pack Inventory (Semgrep Profiles Applied)

Pack ID	Description	Rules	Scope	Version	Change vs Sprint ..	Owner	Last Updated
meridian/general-j..	Java conventions ..	42	Java/Kotlin	2.14.3	+2 rules	MC-SEC-APP	2026-07-12

meridian/api-design	API parameter & r..	18	REST/HTTP	1.9.0	No change	MC-SEC-DC	2026-07-10
meridian/logging-st..	Logging format an..	15	Multi-lang	1.7.5	+1 rule	MC-SEC-APP	2026-07-09
meridian/android-q..	Android coroutine, ..	21	Kotlin/Android	3.2.1	No change	MC-SEC-MOB	2026-07-11
meridian/ios-quality	Swift concurrency ..	19	Swift/iOS	2.6.4	No change	MC-SEC-MOB	2026-07-11
meridian/typescript..	TS strictness, Rea..	24	TS/React	4.1.2	+1 rule	MC-SEC-DC	2026-07-13
meridian/data-seri..	JSON property ord..	12	Java/Kotlin	1.3.8	No change	MC-SEC-APP	2026-07-09
meridian/build-scri..	CI env and script g..	9	YAML/Bash	1.1.6	No change	MC-SEC-PLAT	2026-07-08
meridian/testing	Test fixture and m..	14	Multi-lang	1.0.9	No change	MC-QA-PLAT	2026-07-08
meridian/graphql	Query complexity ..	8	GQL	1.2.0	New pack	MC-SEC-APP	2026-07-12
meridian/document..	Docstring header p..	6	Multi-lang	0.9.2	No change	MC-SEC-APP	2026-07-08
meridian/kotlin-style	Extension function ..	7	Kotlin	1.0.4	No change	MC-SEC-MOB	2026-07-10

SAST Benign Observations Summary (Informational Only)

Rule ID	Title	Repo	File (sample)	Severity	Count	Disposition	JIRA Ref First Se..
meridian/logging-st..	Structured logging ..	core-banking-api	src/main/java/com/..	Info	11	Acknowledged - C..	SEC-14244 2026-..
meridian/api-desig..	Pagination parame..	digital-web-portal	src/api/accounts.ts	Info	7	Closed - Expected ..	SEC-14247 2026-..
meridian/typescript..	React useEffect de..	fraud-detection-ui	src/components/C..	Info	5	Acknowledged - B..	SEC-14255 2026-..
meridian/data-seri..	JSON property ord..	payments-gateway	src/main/java/com/..	Info	4	Closed - Expected ..	SEC-14261 2026-..
meridian/general-j..	Optional used for n..	data-services	src/main/java/com/..	Info	9	Acknowledged - C..	SEC-14266 2026-..
meridian/android-q..	Lifecycle-aware co..	mobile-android	app/src/.../Account..	Info	6	Acknowledged - C..	SEC-14270 2026-..
meridian/ios-qualit..	Standard URLSes..	mobile-ios	Sources/Net/Client..	Info	3	Acknowledged - C..	SEC-14271 2026-..
meridian/build-scri..	CI artifact naming ..	core-banking-api	.github/workflows/b..	Info	2	Closed - Expected ..	SEC-14275 2026-..
meridian/testing:fix..	Test fixtures under..	partner-integration-..	test/fixtures/sampl..	Info	8	Acknowledged - C..	SEC-14278 2026-..
meridian/kotlin-styl..	Extension function..	mobile-android	app/src/.../StringEx..	Info	5	Acknowledged - B..	SEC-14282 2026-..
meridian/document..	File header docs p..	treasury-workbench	src/main/java/.../R..	Info	10	Closed - Expected ..	SEC-14286 2026-..
meridian/graphql:n..	GraphQL type nam..	risk-analytics-svc	src/main/graphql/s..	Info	3	Acknowledged - C..	SEC-14291 2026-..
meridian/typescript..	UI text sourced fro..	fraud-detection-ui	src/i18n/en.json	Info	12	Acknowledged - C..	SEC-14294 2026-..
meridian/api-desig..	Health endpoint ex..	partner-integration-..	src/main/kotlin/.../H..	Info	1	Closed - Expected ..	SEC-14297 2026-..
meridian/logging-st..	Redaction tag pres..	core-banking-api	src/main/java/.../Lo..	Info	4	Acknowledged - C..	SEC-14301 2026-..

SAST/DAST Execution Detail and Cross-Check

During Sprint 42, dynamic scanning validated endpoint availability, response schema stability, and standard header presence across representative service surfaces. Traffic was generated in a controlled pre-production environment with fully synthetic data. Authentication contexts included service accounts and role-scoped user journeys. Combined with SAST outcomes, the scans indicate consistent adoption of Meridian coding conventions and operational readiness indicators, with no actionable items required. The sections below detail DAST coverage, change-review dispositions, and trend metrics across recent sprints.

DAST Endpoint Coverage Summary (Pre-Production)

Service	Endpoint	Method	Auth Context	Sample Status	Avg Latency (ms)	Scan Window (UT..	Notes
core-banking-api	/api/v1/accounts	GET	User: retail-basic	200	182	2026-07-17T10:00..	Returns stable pag..
core-banking-api	/api/v1/accounts/{id}	GET	User: retail-basic	200	195	2026-07-17T10:00..	ID path validation c..
core-banking-api	/actuator/health	GET	None	200	34	2026-07-17T10:00..	Standard health pa..
payments-gateway	/api/v1/payments	POST	Service: pay-svc	201	224	2026-07-18T08:35..	Synthetic payload ..
payments-gateway	/api/v1/payments/{i..	GET	Service: pay-svc	200	209	2026-07-18T08:35..	Correlates to creat..
digital-web-portal	/auth/login	POST	User: portal	200	141	2026-07-17T10:24..	Expected redirect f..
digital-web-portal	/auth/logout	POST	User: portal	204	89	2026-07-17T10:24..	Session cleared
digital-web-portal	/api/profile	GET	User: portal	200	172	2026-07-17T10:24..	JSON schema unc..
data-services	/api/v1/ingest/status	GET	Service: data-inge..	200	96	2026-07-19T12:33..	Status flags as exp..
data-services	/metrics	GET	None	200	51	2026-07-19T12:33..	Metrics endpoint re..
risk-analytics-svc	/graphql	POST	Service: risk-client	200	238	2026-07-19T07:46..	Query shape valid..
partner-integration-..	/api/v1/partners	GET	Service: partner-app	200	188	2026-07-21T16:48..	Pagination stable
partner-integration-..	/actuator/info	GET	None	200	39	2026-07-21T16:48..	Standard info keys..
treasury-workbench	/api/v1/rates	GET	User: treasury-ops	200	174	2026-07-20T15:20..	Currency pairs co..
treasury-workbench	/api/v1/rates/snaps..	POST	User: treasury-ops	202	219	2026-07-20T15:20..	Accepted for proce..
aml-monitor	/api/v1/ingest/heart..	GET	Service: aml-agent	200	81	2026-07-21T10:14..	Heartbeat observed
fraud-detection-ui	/healthz	GET	None	200	28	2026-07-22T08:22..	Health check ok
wealth-mobile	/api/v1/portfolio	GET	User: wealth-retail	200	201	2026-07-20T09:04..	Consistent asset list
mobile-ios-backend	/api/v1/app/config	GET	App: ios	200	93	2026-07-18T11:17..	Config keys stable
mobile-android-ba..	/api/v1/app/config	GET	App: android	200	95	2026-07-18T14:15..	Config keys stable

Change Review Log (Scan-Related, Informational Outcomes)

Ticket	Area	Description	Scan Impact	Decision	Approver	Timestamp (UTC)
SEC-14231	Document Control	Sprint 42 report sc..	Reporting	Approved - Scope ..	Dir. AppSec	2026-07-08T09:12..
APP-9321	Core Banking	DTO field rename f..	SAST	Acknowledged - N..	Lead Dev CB	2026-07-10T14:05..
WEB-842	Digital Portal	Pagination default..	SAST/DAST	Approved - Conve..	DC Security	2026-07-11T10:24..
PAY-6112	Payments	Response wrapper..	DAST	Approved - Schem..	Platform QA	2026-07-12T12:18..
MOB-1632	Android	ViewModel refacto..	SAST	Approved - Style r..	Mobile Sec	2026-07-13T16:02..
IOS-1294	iOS	URLSession initiali..	SAST	Approved - Confor..	Mobile Sec	2026-07-13T16:18..
DATA-571	Data Services	Ingest status flag r..	DAST	Acknowledged - N..	Data Eng Lead	2026-07-14T08:33..
RISK-419	Risk Analytics	GraphQL naming ..	SAST/DAST	Approved - Namin..	AppSec Eng	2026-07-15T09:47..
TRSY-458	Treasury	Rate snapshot asy..	DAST	Approved - Accept..	QA Lead	2026-07-16T13:28..
AML-210	AML Monitor	Heartbeat endpoin..	SAST	Acknowledged - D..	QA Lead	2026-07-17T11:09..
PART-784	Partner Hub	Info endpoint stan..	DAST	Approved - Standa..	DC Security	2026-07-18T15:51..
FRAUD-271	Fraud UI	i18n keys validated	SAST	Acknowledged - C..	UI Lead	2026-07-22T08:12..

Trend Metrics (Sprint 40-42)

Metric	Sprint 40	Sprint 41	Sprint 42	Delta (41->42)	Notes

SAST scans executed	9	10	12	+2	Added risk-analytics-s..
DAST surfaces covered	6	8	10	+2	Mobile config endpoint..
Informational SAST ob..	86	79	81	+2	Stable post-refactor in ..
Median SAST runtime ..	11.3	11.1	11.6	+0.5	Additional packs raise..
Median DAST latency ..	198	193	190	-3	Minor infra tuning imp..
Rule pack changes ap..	2	1	3	+2	Logging, TS UI, Graph..
Confirmed false positi..	5	4	4	0	No change; all informa..
Conformance checks ..	31	34	37	+3	Broader pack coverage
PRs gated by SAST (i..	7	5	6	+1	Notices only; no blocks
DAST schema drift det..	0	0	0	0	Schemas unchanged

Rule Tuning Adjustments (Calibration Only)

Rule ID	Change Type	Rationale	Effect on Findings	Verified By	Date (UTC)
meridian/logging-stan..	Message update	Clarified field order hint	No count change	MC-SEC-APP	2026-07-09
meridian/typescript-ui:..	Pattern broadened	Account for optional pr..	+1 informational in UI r..	MC-SEC-DC	2026-07-13
meridian/api-design:p..	Add alias	Accept "per_page" syn..	-1 informational in web	MC-SEC-DC	2026-07-11
meridian/android-quali..	Message tone	Emphasize lifecycle c..	No count change	MC-SEC-MOB	2026-07-12
meridian/ios-quality:url..	False-positive guard	Ignore test harness ini..	-2 informational in iOS	MC-SEC-MOB	2026-07-13
meridian/data-serializa..	Path filter	Exclude generated DT..	-3 informational in pay..	MC-SEC-APP	2026-07-12
meridian/graphql:nami..	New rule	Align type suffixes	+3 informational in risk..	MC-SEC-APP	2026-07-15
meridian/build-scripts:..	Minor regex	Support hotfix tags	No count change	MC-SEC-PLAT	2026-07-08
meridian/testing:fixture..	Message update	Clarify test paths	No count change	MC-QA-PLAT	2026-07-08
meridian/documentati..	Scope refine	Limit to src directories	-1 informational in part..	MC-SEC-APP	2026-07-14

Summary: Sprint 42 scanning achieved full planned coverage across core services and client applications. All SAST observations are informational and consistent with Meridian standards. DAST traffic confirmed stable endpoint behavior, response schemas, and standard operational headers. No remediation or exception workflows were initiated. The next sprint will extend GraphQL pack adoption and continue latency benchmarking across partner integration flows.

Page 3 -- SAST Rule Execution Metrics and Rule Pack Inventory

The following metrics summarize Semgrep SAST rule execution across Meridian Capital repositories during Sprint 42. All critical and high-severity categories returned zero matches. Informational matches were logged for baseline hygiene monitoring and trend analysis only. Scans executed via centralized CI pipelines and adhered to Meridian AppSec baselines. Audit tickets and reviewers are listed for traceability.

SAST Rule Execution Summary by Repository (Sprint 42)

Repo	Component	Team	Branch	Commit	Pipeline ID	Scan Window Start	Scan Window En..
digital-banking-ser..	account-ledger	Retail Banking Tech	main	6f2a9d1	CI-20260715-DBS-..	2026-07-12 02:10 ..	2026-07-15 09:35 ..
onboarding-portal	customer-intake	Digital Channels	main	0bb7e32	CI-20260716-ONB..	2026-07-13 06:42 ..	2026-07-16 11:22 ..
risk-analytics	model-evaluator	Risk Engineering	release/2026.07	d1a3c4e	CI-20260714-RISK..	2026-07-11 20:15 ..	2026-07-14 08:09 ..
payments-gateway	tx-router	Payments Platform	main	7c9fd22	CI-20260718-PAY-..	2026-07-15 03:55 ..	2026-07-18 12:01 ..
treasury-ops	liquidity-svc	Treasury Tech	develop	b2de5aa	CI-20260717-TRE-..	2026-07-14 10:10 ..	2026-07-17 07:28 ..
wealth-mobile-ios	portfolio-app	WealthTech	release/4.12	91a0c77	CI-20260713-WIO..	2026-07-10 22:44 ..	2026-07-13 05:31 ..
wealth-mobile-andr..	portfolio-app	WealthTech	release/4.12	e34b1d4	CI-20260713-WAN..	2026-07-10 23:18 ..	2026-07-13 06:10 ..
data-pipelines	etl-core	Data Engineering	main	c8ef9a8	CI-20260719-DAT..	2026-07-16 01:30 ..	2026-07-19 09:02 ..
reporting-portal	analytics-ui	BI & Reporting	main	4aa1b30	CI-20260718-RPT-..	2026-07-15 08:56 ..	2026-07-18 15:24 ..
auth-service	token-broker	Identity & Access	main	f7b5319	CI-20260712-AUT..	2026-07-09 12:20 ..	2026-07-12 13:55 ..
notification-service	comms-dispatch	Messaging Platfor..	develop	d83a12f	CI-20260717-NOTI..	2026-07-14 13:33 ..	2026-07-17 10:01 ..
merchant-onboardi..	partner-kyc	Partnerships Tech	main	a5510c9	CI-20260716-MOB..	2026-07-13 09:40 ..	2026-07-16 08:18 ..
card-platform	card-core	Card Technology	release/3.8	2b7f35e	CI-20260715-CAR..	2026-07-12 04:29 ..	2026-07-15 14:02 ..
core-banking	general-ledger	Core Systems	main	a4d93ab	CI-20260718-COR..	2026-07-15 02:45 ..	2026-07-18 13:11 ..
pricing-engine	fx-quoter	Markets Technology	develop	7ed4410	CI-20260714-PRC..	2026-07-11 21:57 ..	2026-07-14 09:40 ..
api-gateway	edge-proxy	Platform Services	main	1c9e0a2	CI-20260719-API-..	2026-07-16 06:13 ..	2026-07-19 07:47 ..
docs-portal	developer-docs	Developer Experie..	main	3db7f81	CI-20260711-DOC..	2026-07-08 17:05 ..	2026-07-11 03:12 ..
kyc-service	id-verifier	Compliance Tech	main	0c1eaa5	CI-20260716-KYC-..	2026-07-13 07:18 ..	2026-07-16 09:45 ..
loan-origination	underwriting-core	Lending Tech	develop	5f1477b	CI-20260715-LOA..	2026-07-12 11:02 ..	2026-07-15 16:21 ..
ops-automation	runbook-bot	Platform Ops	main	8a4bd9e	CI-20260717-OPS..	2026-07-14 05:30 ..	2026-07-17 12:37 ..
analytics-foundation	feature-store	Data Science Platf..	main	c01da5c	CI-20260718-AF-6..	2026-07-15 14:41 ..	2026-07-18 18:09 ..
service-catalog	discovery-api	Platform Services	main	49afc72	CI-20260719-CAT-..	2026-07-16 04:12 ..	2026-07-19 11:53 ..

Rule Pack Inventory and Versioning (Applied During Sprint 42)

Rule Pack Name	Version	Publisher	Rule Count	Security Coverag..	Last Updated	Hash	Applied To Repos..
meridian-internal/p..	42.7.1	Meridian AppSec	412	100	2026-07-10	e6f3a9c1	9 Includes formatti..
meridian-internal/ja..	42.6.4	Meridian AppSec	365	100	2026-07-09	9b10e5d8	6 Android and serv..
meridian-internal/s..	42.5.2	Meridian AppSec	281	100	2026-07-08	7d22c3f0	3 Aligned with iOS ..
meridian-internal/js..	42.7.0	Meridian AppSec	398	100	2026-07-11	3a2b4c9e	5 UI lint and hygie..
meridian-internal/g..	42.3.9	Meridian AppSec	274	100	2026-07-07	2f8e7d1a	4 Concurrency and..
semgrep-registry/g..	1.22.0	Semgrep Registry	520	100	2026-07-03	a1c3e5f7	12 Limited to non-i..
meridian-internal/s..	42.2.5	Meridian AppSec	226	100	2026-07-06	d0b9a441	2 Spark serializatio..
meridian-internal/d..	42.4.3	Meridian AppSec	305	100	2026-07-08	4e7c9b22	2 Applied to card-p..
meridian-internal/r..	42.1.8	Meridian AppSec	198	100	2026-07-05	6f1a2d9b	1 Informational ho..
meridian-internal/in..	42.6.1	Meridian AppSec	167	100	2026-07-09	8b5f0a11	3 CI helper scripts ..
meridian-internal/ty..	42.7.2	Meridian AppSec	152	100	2026-07-11	5a8d3c77	7 Type annotations..
meridian-internal/s..	42.3.4	Meridian AppSec	140	100	2026-07-07	0c7e19e2	10 Verifies explicit ..
meridian-internal/lo..	42.6.0	Meridian AppSec	124	100	2026-07-09	b2d9f0c3	14 Ensures consist..
meridian-internal/d..	42.5.7	Meridian AppSec	96	100	2026-07-08	c1e4a2d0	6 Markdown and c..
meridian-internal/t..	42.7.3	Meridian AppSec	88	100	2026-07-11	f3b7d9a8	16 Separates test f..

Page 4 -- Non-Actionable SAST Observations and DAST Passive Snapshots

This page records benign SAST observations reviewed and closed during Sprint 42 along with DAST passive verification snapshots. All entries were confirmed compliant with Meridian standards or scoped to non-production contexts (tests, mocks, documentation). No policy exceptions were required, and no corrective actions were opened.

Non-Actionable SAST Observations (Benign or Compliant)

Observation ID	Rule ID	Title	Severity	Disposition	Repo	Path	Line Range First ..
OBS-42-001	MER-LOG-TEST-0..	Debug logger in un..	Info	Benign -- Test Sco..	auth-service	tests/helpers/loggi..	L15-L22 2026-07-0..
OBS-42-002	MER-COMMENT-..	TODO markers in ..	Info	Compliant	docs-portal	docs/roadmap.md	L3-L18 2026-07-08..
OBS-42-003	MER-SERIAL-003	Explicit serializer hi..	Low	Compliant	data-pipelines	etl/encoders/json_..	L40-L58 2026-07-1..
OBS-42-004	MER-NAMING-004	Non-standard enu..	Info	Accepted -- Style	pricing-engine	src/fx/quotes/enum..	L8-L14 2026-07-11..
OBS-42-005	MER-IMPORT-005	Duplicate import in..	Info	Benign -- Test Sco..	onboarding-portal	tests/ui/form_test.ts	L2-L5 2026-07-13 ..
OBS-42-006	MER-ASSERT-006	Assertion usage in ..	Info	Compliant	auth-service	tests/token/asserti..	L30-L49 2026-07-0..
OBS-42-007	MER-DOC-007	Extended docstrin..	Info	Compliant	analytics-foundation	src/feature/registry..	L4-L28 2026-07-15..
OBS-42-008	MER-LOG-008	Structured log key ..	Info	Accepted -- Style	api-gateway	pkg/edge/logging.go	L61-L78 2026-07-1..
OBS-42-009	MER-MOCK-009	No-op handler in m..	Info	Benign -- Test Sco..	notification-service	test/mocks/dispatc..	L12-L25 2026-07-1..
OBS-42-010	MER-GEN-010	Generated client e..	Info	Compliant	service-catalog	gen/discovery_clie..	L1-L200 2026-07-1..
OBS-42-011	MER-CODESTYL..	Long line in Markd..	Info	Compliant	docs-portal	docs/usage.md	L90-L112 2026-07-..
OBS-42-012	MER-TESTDATA-..	Placeholder data i..	Info	Benign -- Test Sco..	kyc-service	tests/fixtures/ids.js..	L1-L40 2026-07-13..
OBS-42-013	MER-TS-013	Optional chaining ..	Info	Compliant	reporting-portal	src/components/C..	L55-L72 2026-07-1..
OBS-42-014	MER-DOC-014	SPDX license hea..	Info	Compliant	card-platform	src/common/Sessi..	L1-L12 2026-07-12..
OBS-42-015	MER-BUILD-015	Suppressed linter ..	Info	Compliant	core-banking	build.gradle	L80-L96 2026-07-1..
OBS-42-016	MER-NULL-016	Redundant null co..	Info	Accepted -- Style	loan-origination	src/underwriting/sc..	L102-L116 2026-0..
OBS-42-017	MER-TEST-017	Snapshot filename..	Info	Compliant	onboarding-portal	tests/snapshots/for..	L1-L1 2026-07-13 ..
OBS-42-018	MER-ENUM-018	Enum default bran..	Info	Compliant	pricing-engine	src/fx/core/Router.kt	L120-L142 2026-0..
OBS-42-019	MER-LOGFMT-019	Log placeholder or..	Info	Accepted -- Style	payments-gateway	services/router/log..	L44-L63 2026-07-1..
OBS-42-020	MER-COMMENT-..	Multi-line comments	Info	Compliant	treasury-ops	src/liquidity/limits.go	L20-L37 2026-07-1..
OBS-42-021	MER-TYPE-021	Explicit any in type	Info	Accepted -- Style	reporting-portal	src/utils/format.ts	L12-L28 2026-07-1..
OBS-42-022	MER-TEST-022	Disabled flaky test ..	Info	Compliant	digital-banking-ser..	tests/ledger/retry_s..	L5-L9 2026-07-12 ..
OBS-42-023	MER-GEN-023	Codegen checksu..	Info	Compliant	service-catalog	gen/openapi_client..	L1-L5 2026-07-16 ..
OBS-42-024	MER-LINT-024	Prettier ignore pra..	Info	Compliant	onboarding-portal	src/styles/theme.ts	L1-L3 2026-07-13 ..
OBS-42-025	MER-TEST-025	Benchmark annota..	Info	Compliant	analytics-foundation	tests/perf/feature_..	L2-L18 2026-07-15..

DAST Passive Validation Snapshots (Headers and Hygiene)

Scan ID	Target Label	Environment	Window Start	Window End	Passive Checks E..	Critical Observed	High Observed M..
DAST-42-101	digital-banking-web	staging	2026-07-12 04:20 ..	2026-07-12 04:42 ..	54	0	0 0 Headers align ..
DAST-42-102	onboarding-portal	staging	2026-07-13 07:12 ..	2026-07-13 07:33 ..	52	0	0 0 TLS and redire..
DAST-42-103	payments-gateway..	staging	2026-07-15 05:05 ..	2026-07-15 05:26 ..	57	0	0 0 Compression a..
DAST-42-104	reporting-portal-ui	staging	2026-07-15 10:40 ..	2026-07-15 11:02 ..	49	0	0 0 CSP baseline c..
DAST-42-105	auth-service-oauth	staging	2026-07-11 13:22 ..	2026-07-11 13:41 ..	58	0	0 0 Strict transport ..
DAST-42-106	notification-endpoi..	staging	2026-07-14 14:09 ..	2026-07-14 14:30 ..	47	0	0 0 Content types ..
DAST-42-107	kyc-service-ui	staging	2026-07-13 10:05 ..	2026-07-13 10:27 ..	51	0	0 0 Cookie flags o..
DAST-42-108	card-platform-admin	staging	2026-07-12 16:30 ..	2026-07-12 16:52 ..	53	0	0 0 Frame and refe..
DAST-42-109	api-gateway-edge	staging	2026-07-16 07:00 ..	2026-07-16 07:21 ..	60	0	0 0 Header normali..
DAST-42-110	service-catalog-ui	staging	2026-07-16 05:22 ..	2026-07-16 05:44 ..	46	0	0 0 HSTS and cac..
DAST-42-111	core-banking-portal	staging	2026-07-15 03:11 ..	2026-07-15 03:35 ..	55	0	0 0 CSP and X-Fra..
DAST-42-112	treasury-ops-cons..	staging	2026-07-14 06:48 ..	2026-07-14 07:10 ..	50	0	0 0 Cookies secur..
DAST-42-113	merchant-onboardi..	staging	2026-07-13 11:18 ..	2026-07-13 11:39 ..	48	0	0 0 Redirect chain..
DAST-42-114	wealth-mobile-api	staging	2026-07-10 23:59 ..	2026-07-11 00:18 ..	44	0	0 0 API responses ..
DAST-42-115	wealth-mobile-web..	staging	2026-07-10 23:21 ..	2026-07-10 23:42 ..	43	0	0 0 CSP baseline f..

All SAST observations above were dispositioned as benign or compliant following two-person review by the AppSec duty engineer and the corresponding product team lead. DAST passive validations confirmed adherence to Meridian's baseline header, transport, and caching standards across staging endpoints during Sprint 42. No follow-up actions were created, and monitoring continues under standard cadence.

Page 5 -- Semgrep SAST Coverage and Triage Outcomes

This page summarizes Semgrep SAST coverage executed during Sprint 42 across Meridian Capital's priority repositories. The content is limited to benign operational metrics and triage outcomes for informational and style-oriented matches that do not represent security defects. No actionable security issues were recorded this sprint. The following tables provide run metadata, service-by-service coverage, and the disposition of informational findings reviewed by the Application Security and owning engineering teams between 2026-07-15 and 2026-07-22 UTC.

Scan Run Summary (Sprint 42 Window)

Field	Value
Report Title	SAST/DAST Security Scan Report -- Sprint 42
Business Unit	Meridian Capital -- Corporate Technology
Scan Engine	Semgrep Cloud Platform
Semgrep Version	1.65.0 (enterprise channel)
Rulepack Revision	rp-2026.07.15-rc1 (mrc-internal, owasp-bp, style-suite)
Pipeline Job	ci-2026.07.21-042 (nightly, orchestrator v3.8)
Commit Scope	Monorepo HEAD a3f1e2c (plus 7 service branches)
Repositories Scanned	18 (service repos), 1 (shared libraries), 1 (infra-aux)
Total Files Scanned	149,237
Total Rules Evaluated	2,184
Duration (wall/CPU)	00:36:58 / 06:12:43
Cache Hit Rate	81.6% (path + AST)
Owner (Ops)	SecEng Automation (Team: AppSec Platform)
Timestamp (UTC)	2026-07-21T07:28:49Z

Service Coverage Matrix (Informational/Style-Only Matches)

Service	Repository	Team	Scan Window	Rulepack Rev	Rules Evaluated	Matches (Info)	Matches (Style) C..
Core-Ledger	git@mrc/core-ledg..	Core Banking	Sprint 42	rp-2026.07.15-rc1	2,184	42	18 7 5 Completed ..
Payments-API	git@mrc/payments..	Payments Platform	Sprint 42	rp-2026.07.15-rc1	2,184	55	21 9 7 Completed ..
Treasury-Portal	git@mrc/treasury-p..	Treasury Technolo..	Sprint 42	rp-2026.07.15-rc1	2,184	33	14 6 4 Completed ..
Risk-Engine	git@mrc/risk-engin..	Risk & Quant	Sprint 42	rp-2026.07.15-rc1	2,184	29	11 4 3 Completed ..
Data-Pipeline	git@mrc/data-pipel..	Data Engineering	Sprint 42	rp-2026.07.15-rc1	2,184	48	16 8 6 Completed ..
Mobile-iOS	git@mrc/mobile-io..	Mobile Engineering	Sprint 42	rp-2026.07.15-rc1	1,762	27	13 5 3 Completed ..
Mobile-Android	git@mrc/mobile-an..	Mobile Engineering	Sprint 42	rp-2026.07.15-rc1	1,811	31	19 6 2 Completed ..
Web-UI	git@mrc/web-ui.git	Digital Channels	Sprint 42	rp-2026.07.15-rc1	2,017	62	37 10 9 Completed..
Client-Onboarding	git@mrc/client-onb..	Digital Channels	Sprint 42	rp-2026.07.15-rc1	2,184	22	9 3 2 Completed D..
KYC-Service	git@mrc/kyc-servic..	Compliance Tech	Sprint 42	rp-2026.07.15-rc1	2,184	19	7 5 1 Completed C..
Reporting-ETL	git@mrc/reporting-..	Data Engineering	Sprint 42	rp-2026.07.15-rc1	2,184	44	12 7 4 Completed ..
Analytics-ML	git@mrc/analytics-..	Risk & Quant	Sprint 42	rp-2026.07.15-rc1	2,184	24	8 4 2 Completed R..
Messaging-Gatew..	git@mrc/messagin..	Core Banking	Sprint 42	rp-2026.07.15-rc1	2,184	37	15 6 3 Completed ..
Identity-Provider	git@mrc/identity-pr..	IAM	Sprint 42	rp-2026.07.15-rc1	2,184	21	10 4 2 Completed I..
Authorization-Servi..	git@mrc/authorizat..	IAM	Sprint 42	rp-2026.07.15-rc1	2,184	23	12 4 2 Completed I..
Notification-Service	git@mrc/notificatio..	Digital Channels	Sprint 42	rp-2026.07.15-rc1	2,184	36	13 5 4 Completed ..
FX-Rates	git@mrc/fx-rates.git	Treasury Technolo..	Sprint 42	rp-2026.07.15-rc1	2,184	18	9 3 1 Completed S..
Loan-Origination	git@mrc/loan-origi..	Retail Lending Tech	Sprint 42	rp-2026.07.15-rc1	2,184	41	17 6 5 Completed ..
Trade-Settlement	git@mrc/trade-settl..	Markets Tech	Sprint 42	rp-2026.07.15-rc1	2,184	28	12 4 2 Completed ..
Cards-Gateway	git@mrc/cards-gat..	Payments Platform	Sprint 42	rp-2026.07.15-rc1	2,184	26	11 4 2 Completed ..

Triage Disposition Log (Informational and Style Findings Only)

Finding ID	Rule ID	Severity	Category	Location	Build	Owner	Disposition Reas..
SAST-SG-104551	mrc.logging.consis..	Info	Style	core-ledger/service..	ci-2026.07.21-042	Core Banking	Not Applicable ST..
SAST-SG-104552	mrc.docs.header.li..	Info	Documentation	payments-api/hand..	ci-2026.07.21-042	Payments Platform	Accepted as Desig..
SAST-SG-104553	semgrep.python.b..	Low	Style	kyc-service/tasks/e..	ci-2026.07.21-042	Compliance Tech	Merge Candidate (..
SAST-SG-104554	mrc.todo.marker.tri..	Info	Process	web-ui/src/compon..	ci-2026.07.21-042	Digital Channels	Tracked PROCES..
SAST-SG-104555	mrc.deadcode.unr..	Info	Quality	risk-engine/src/pip..	ci-2026.07.21-042	Risk & Quant	Accepted as Desig..
SAST-SG-104556	mrc.test.only.asser..	Info	Test Scope	identity-provider/te..	ci-2026.07.21-042	IAM	Not Applicable TE..
SAST-SG-104557	mrc.logging.no-tabs	Info	Style	data-pipeline/jobs/t..	ci-2026.07.21-042	Data Engineering	Merge Candidate (..
SAST-SG-104558	mrc.format.string.si..	Info	Style	treasury-portal/app..	ci-2026.07.21-042	Treasury Technolo..	Not Applicable ST..
SAST-SG-104559	mrc.import.ordering	Info	Style	messaging-gatewa..	ci-2026.07.21-042	Core Banking	Merge Candidate (..
SAST-SG-104560	mrc.comment.form..	Info	Documentation	analytics-ml/experi..	ci-2026.07.21-042	Risk & Quant	Accepted as Desig..
SAST-SG-104561	mrc.lint.trailing-whi..	Info	Style	mobile-ios/App/Sc..	ci-2026.07.21-042	Mobile Engineering	Merge Candidate (..
SAST-SG-104562	mrc.kotlin.explicit-t..	Info	Style	mobile-android/ap..	ci-2026.07.21-042	Mobile Engineering	Not Applicable ST..
SAST-SG-104563	mrc.todo.marker.tri..	Info	Process	client-onboarding/s..	ci-2026.07.21-042	Digital Channels	Tracked PROCES..
SAST-SG-104564	mrc.logging.placeh..	Info	Style	authorization-svc/p..	ci-2026.07.21-042	IAM	Accepted as Desig..
SAST-SG-104565	mrc.license.header..	Info	Compliance Taggi..	reporting-etl/lib/run..	ci-2026.07.21-042	Data Engineering	Not Applicable CO..
SAST-SG-104566	mrc.ts.strict-null-ok	Info	Style	web-ui/src/utils/dat..	ci-2026.07.21-042	Digital Channels	Merge Candidate (..
SAST-SG-104567	mrc.scala.match-e..	Info	Documentation	risk-engine/src/pip..	ci-2026.07.21-042	Risk & Quant	Accepted as Desig..
SAST-SG-104568	mrc.go.comment.c..	Info	Documentation	core-ledger/interna..	ci-2026.07.21-042	Core Banking	Merge Candidate (..
SAST-SG-104569	mrc.js.prefer-const	Info	Style	notification-svc/src/..	ci-2026.07.21-042	Digital Channels	Merge Candidate (..
SAST-SG-104570	mrc.yaml.key-order	Info	Style	fx-rates/config/pipe..	ci-2026.07.21-042	Treasury Technolo..	Not Applicable ST..
SAST-SG-104571	mrc.go.error-wrap-..	Info	Style	authorization-svc/p..	ci-2026.07.21-042	IAM	Accepted as Desig..
SAST-SG-104572	mrc.kotlin.kdoc.mis..	Info	Documentation	mobile-android/ap..	ci-2026.07.21-042	Mobile Engineering	Not Applicable DO..
SAST-SG-104573	mrc.ts.no-implicit-a..	Low	Style	web-ui/src/store/in..	ci-2026.07.21-042	Digital Channels	Merge Candidate (..
SAST-SG-104574	mrc.scala.import-g..	Info	Style	trade-settlement/sr..	ci-2026.07.21-042	Markets Tech	Accepted as Desig..
SAST-SG-104575	mrc.swift.comment..	Info	Documentation	mobile-ios/App/Ser..	ci-2026.07.21-042	Mobile Engineering	Accepted as Desig..

All items above are informational or style-related and have been dispositioned accordingly, requiring no security response or exception handling.

Page 6 -- False Positive Review Queue and Rule Tuning Backlog

This page provides operational visibility into the false positive review queue and proposed rule tuning items scheduled for subsequent sprints. The queue focuses on benign, non-security rules where pattern specificity or repository scoping can be improved to reduce noise. All items are tracked in Jira with accountable engineering owners and agreed SLAs. No policy exceptions are requested or required. Performance metrics for representative CI jobs are also recorded to inform tuning prioritization.

False Positive Review Queue (Benign/Noise Reduction)

Queue ID	Rule ID	Pattern Summary	Repro Status	Sample File	Team	First Seen	Count (7d) Priorit..
FPQ-7421	mrc.todo.marker.tri..	TODO tag in com..	N/A	web-ui/src/api.ts	Digital Channels	2026-07-15	19 P4 10 bd DC-S..
FPQ-7422	mrc.docs.header.li..	License header pr..	N/A	payments-api/hand..	Payments Platform	2026-07-15	11 P5 15 bd AppS..
FPQ-7423	mrc.logging.placeh..	Mismatch count be..	N/A	authorization-svc/p..	IAM	2026-07-16	7 P4 10 bd IAM-Re..
FPQ-7424	mrc.lint.trailing-whi..	Trailing whitespace	N/A	mobile-ios/App/Sc..	Mobile Engineering	2026-07-16	23 P5 15 bd Mobil..
FPQ-7425	mrc.kotlin.kdoc.mis..	Missing KDoc com..	N/A	mobile-android/ap..	Mobile Engineering	2026-07-16	14 P5 15 bd Mobil..
FPQ-7426	mrc.import.ordering	Import order varian..	N/A	messaging-gatewa..	Core Banking	2026-07-17	13 P5 20 bd AppS..
FPQ-7427	mrc.comment.form..	Comment punctuat..	N/A	analytics-ml/experi..	Risk & Quant	2026-07-17	6 P5 20 bd Risk-O..
FPQ-7428	mrc.ts.strict-null-ok	TS null checks sug..	N/A	web-ui/src/utils/dat..	Digital Channels	2026-07-17	17 P4 10 bd DC-S..
FPQ-7429	mrc.go.comment.c..	Go doc sentence	N/A	core-ledger/interna..	Core Banking	2026-07-18	9 P5 15 bd AppSe..
FPQ-7430	mrc.scala.import-g..	Scala import group..	N/A	trade-settlement/sr..	Markets Tech	2026-07-18	5 P5 20 bd Market..
FPQ-7431	mrc.ts.no-implicit-a..	Implicit any annota..	N/A	web-ui/src/store/in..	Digital Channels	2026-07-18	12 P4 10 bd DC-S..
FPQ-7432	mrc.js.prefer-const	Prefer const sugge..	N/A	notification-svc/src/..	Digital Channels	2026-07-19	10 P5 15 bd DC-S..
FPQ-7433	mrc.yaml.key-order	YAML key order	N/A	fx-rates/config/pipe..	Treasury Technolo..	2026-07-19	8 P5 20 bd SecOp..
FPQ-7434	mrc.kotlin.explicit-t..	Explicit type on val	N/A	mobile-android/ap..	Mobile Engineering	2026-07-19	11 P5 15 bd Mobil..
FPQ-7435	mrc.go.error-wrap-..	Wrap style uniform..	N/A	authorization-svc/p..	IAM	2026-07-19	7 P5 20 bd IAM-Re..
FPQ-7436	mrc.format.string.si..	f-string simplification	N/A	treasury-portal/app..	Treasury Technolo..	2026-07-20	6 P5 20 bd SecOp..
FPQ-7437	mrc.logging.no-tabs	No tabs in logs	N/A	data-pipeline/jobs/t..	Data Engineering	2026-07-20	15 P4 10 bd DataS..
FPQ-7438	mrc.test.only.asser..	Test assertions pre..	N/A	identity-provider/te..	IAM	2026-07-20	9 P5 15 bd IAM-Re..
FPQ-7439	mrc.license.header..	Header presence o..	N/A	reporting-etl/lib/run..	Data Engineering	2026-07-20	4 P5 20 bd DataSe..
FPQ-7440	mrc.swift.comment..	Swift comments st..	N/A	mobile-ios/App/Ser..	Mobile Engineering	2026-07-20	10 P5 15 bd Mobil..

Proposed Rule Tuning Changes (Scheduled/Planned)

Proposal ID	Rule ID	Change Type	Rationale	Scope	Risk	Affected Repos	Est. Impact (nois..
RT-5811	mrc.todo.marker.tri..	Add path filter	Avoid flagging buil..	web-ui, client-onbo..	None	2	40-60% DC-SecCo..
RT-5812	mrc.docs.header.li..	Ignore codegen dirs	Generated files lac..	reporting-etl, paym..	None	3	70-80% AppSec-R..
RT-5813	mrc.logging.placeh..	Allow known forma..	Benign wrapper alt..	authorization-svc	None	1	50-70% IAM-Revie..
RT-5814	mrc.lint.trailing-whi..	Delegate to linters	CI already enforces	mobile-ios, web-ui	None	4	80-90% MobileSec..
RT-5815	mrc.kotlin.kdoc.mis..	Restrict symbol vis..	Comments on publ..	mobile-android	None	1	60-80% MobileSec..
RT-5816	mrc.import.ordering	Follow ktlint/scalaf..	Prevent duplicate ..	messaging-gatewa..	None	2	70-85% AppSec-R..
RT-5817	mrc.comment.form..	Exempt configs	Punctuation not re..	analytics-ml, fx-rat..	None	2	65-75% Risk-Own..
RT-5818	mrc.ts.strict-null-ok	Align with tsconfig	Avoid redundant a..	web-ui	None	1	50-70% DC-SecCo..
RT-5819	mrc.ts.no-implicit-a..	Ignore legacy folder	Gradual migration ..	web-ui	None	1	55-65% DC-SecCo..
RT-5820	mrc.js.prefer-const	Delegate to eslint	Prefer standard lint..	notification-svc	None	1	75-85% DC-SecCo..
RT-5821	mrc.yaml.key-order	Exclude ops config	Order is maintaine..	fx-rates	None	1	60-80% SecOps-A..
RT-5822	mrc.kotlin.explicit-t..	Prefer IDE inspecti..	Avoid duplicate noi..	mobile-android	None	1	70-85% MobileSec..
RT-5823	mrc.go.comment.c..	Exported funcs only	Internal code less ..	core-ledger	None	1	55-70% AppSec-R..
RT-5824	mrc.go.error-wrap-..	Document standard	Accept house style	authorization-svc	None	1	60-80% IAM-Revie..
RT-5825	mrc.format.string.si..	Exempt templates	Templating engine..	treasury-portal	None	1	65-75% SecOps-A..

CI Scan Performance Metrics (Representative Jobs)

Job ID	Pipeline	Repository	Node Size	Rules Evaluated	Files Scanned	Parse Failures	Time (mm:ss) Ca..
PERF-9001	nightly-042	core-ledger	m5.4xlarge	2,184	11,902	0	06:12 82% 8 Stable
PERF-9002	nightly-042	payments-api	m5.4xlarge	2,184	9,443	0	05:47 84% 8 Stable
PERF-9003	nightly-042	treasury-portal	m5.4xlarge	2,184	7,118	0	04:36 80% 8 Stable
PERF-9004	nightly-042	risk-engine	m5.4xlarge	2,184	6,021	1	04:52 78% 8 1 ben..
PERF-9005	nightly-042	data-pipeline	m5.4xlarge	2,184	12,607	0	06:41 83% 8 Stable
PERF-9006	nightly-042	mobile-ios	m5.2xlarge	1,762	5,384	0	03:55 79% 6 Stable
PERF-9007	nightly-042	mobile-android	m5.2xlarge	1,811	6,037	0	04:03 77% 6 Stable
PERF-9008	nightly-042	web-ui	m5.4xlarge	2,017	13,290	0	07:08 85% 8 High ..
PERF-9009	nightly-042	identity-provider	m5.4xlarge	2,184	4,512	0	03:21 76% 8 Stable
PERF-9010	nightly-042	authorization-svc	m5.4xlarge	2,184	4,201	0	03:14 77% 8 Stable
PERF-9011	nightly-042	reporting-etl	m5.4xlarge	2,184	8,119	0	05:02 82% 8 Stable
PERF-9012	nightly-042	messaging-gateway	m5.4xlarge	2,184	5,714	0	03:49 80% 8 Stable

All items above represent routine operational tracking for Semgrep SAST within Sprint 42. No security vulnerabilities were surfaced or reported from these queues or performance evaluations.

Meridian Capital -- SAST/DAST Security Scan Report -- Sprint 42

Page 7: SAST Triage Summary and Scan Metrics

The following page summarizes informational and maintainability-class findings from Semgrep SAST scans conducted during Sprint 42. All items listed were reviewed and closed as non-actionable or tracked for routine housekeeping. No risk-bearing issues were identified. Entries include traceability to CI runs, tickets, and responsible teams for audit continuity.

Table 7.1 -- Benign Findings Reviewed (Informational/Maintainability)

Finding ID	Rule ID	Classification	Status	Repository	Path	Lines	Commit Scan Tim..
SAST-FN-00721	MC_STYLE_LOG_..	Logging format co..	Closed -- Expected..	core-payments-api	src/logging/Logger...	88-97	3f2ab19 2026-07-1..
SAST-FN-00722	MC_DOC_HEADE..	License header pr..	Closed -- Header p..	treasury-risk-models	models/credit/VaR..	1-20	9a41c77 2026-07-..
SAST-FN-00723	MC_TEST_NAMIN..	Test naming conve..	Accepted -- Backlo..	digital-banking-app	tests/ui/test_accou..	10-36	1b7c2c3 2026-07-..
SAST-FN-00724	MC_CFG_DEFAU..	Default config expli..	Closed -- Explicit d..	analytics-ingestion	conf/pipeline.yaml	4-8	c57d8f2 2026-07-1..
SAST-FN-00725	MC_I18N_UNUSE..	Unreferenced i18n ..	Closed -- Purge sc..	digital-banking-app	src/i18n/en.json	220-223	6a2f1de 2026-07-1..
SAST-FN-00726	MC_TS_ANY_GE..	any type in generat..	Closed -- Generate..	onboarding-portal	src/gen/models.ts	1-200	0ddf9a0 2026-07-1..
SAST-FN-00727	MC_COMMENTS_..	TODO comment d..	Open -- Tracked vi..	core-payments-api	src/service/Settlem..	115-118	3f2ab19 2026-07-1..
SAST-FN-00728	MC_FORMAT_TR..	Trailing whitespace	Closed -- Autoform..	quant-research-infra	notebooks/alpha.ip..	n/a	f5e48a1 2026-07-1..
SAST-FN-00729	MC_IMPORT_UN..	Unused import	Closed -- Lint-own..	treasury-risk-models	models/shared/util..	12-13	9a41c77 2026-07-..
SAST-FN-00730	MC_JSON_DUP_..	Duplicate YAML/J..	Closed -- Last-win..	infra-pipelines	manifests/etl.yaml	33-39	a2b0c6e 2026-07-..
SAST-FN-00731	MC_BUILD_DEPR..	Deprecated build s..	Closed -- Stub rem..	core-ledger	build/legacy.gradle	1-120	2a66fa0 2026-07-1..
SAST-FN-00732	MC_TEST_IGNOR..	Ignored unit tests	Accepted -- Experi..	onboarding-portal	test/unit/UserStub.t..	2-20	0ddf9a0 2026-07-1..
SAST-FN-00733	MC_LOG_PLACE..	Placeholder interp..	Closed -- Safe tem..	analytics-ingestion	src/metrics/logging..	60-72	c57d8f2 2026-07-1..
SAST-FN-00734	MC_NAMING_CO..	Constant naming c..	Closed -- Project st..	core-ledger	src/main/java/com/..	44-54	2a66fa0 2026-07-1..
SAST-FN-00735	MC_DOC_TYPO_..	Comment spelling	Closed -- Editorial	quant-research-infra	libs/stat/kalman.py	5-7	f5e48a1 2026-07-1..
SAST-FN-00736	MC_CFG_FLAG_..	Debug flag default ..	Closed -- Confirme..	digital-banking-app	src/config/defaults...	12-16	6a2f1de 2026-07-1..
SAST-FN-00737	MC_SCHEMA_DO..	Schema docstring ..	Closed -- Complete	analytics-ingestion	schemas/payment..	1-30	c57d8f2 2026-07-1..
SAST-FN-00738	MC_LIC_EXCLUSI..	Generated header ..	Closed -- In exclusi..	onboarding-portal	src/gen/client.ts	1-10	0ddf9a0 2026-07-1..
SAST-FN-00739	MC_PROTO_STY..	Proto style guideline	Closed -- Legacy a..	core-ledger	proto/ledger.proto	3-25	2a66fa0 2026-07-1..
SAST-FN-00740	MC_SQL_FMT_016	SQL formatting sta..	Closed -- Formatte..	treasury-risk-models	sql/features/loans...	1-40	9a41c77 2026-07-..

Table 7.2 -- Repository-Level Coverage and Noise Metrics

Repository	Semgrep Pack Ve..	Active Rules	Informational Hits	Closed as Non-Is..	Signal-to-Noise	Median Review Ti..	SLA Met Last Full..
core-payments-api	mc-semgrep-pack ..	184	62	62	1:0 (no actionable)	22m	Yes 2026-07-18T0..
digital-banking-app	mc-semgrep-pack ..	176	71	69	1:0 (no actionable)	25m	Yes 2026-07-18T0..
treasury-risk-models	mc-semgrep-pack ..	191	54	54	1:0 (no actionable)	18m	Yes 2026-07-18T0..
analytics-ingestion	mc-semgrep-pack ..	168	47	47	1:0 (no actionable)	20m	Yes 2026-07-18T0..
onboarding-portal	mc-semgrep-pack ..	159	58	58	1:0 (no actionable)	19m	Yes 2026-07-18T0..
core-ledger	mc-semgrep-pack ..	172	49	49	1:0 (no actionable)	21m	Yes 2026-07-18T0..
quant-research-infra	mc-semgrep-pack ..	140	33	33	1:0 (no actionable)	16m	Yes 2026-07-18T0..
infra-pipelines	mc-semgrep-pack ..	132	29	29	1:0 (no actionable)	14m	Yes 2026-07-18T0..

Table 7.3 -- Scan Performance by Runner

CI Job ID	Runner	OS Image	Repos Scanned	Duration (mm:ss)	Peak RSS (MB)	Semgrep Version	Cache Used Exit ..
CI-874201	mc-runner-az-17	ubuntu-22.04	1	06:41	812	1.68.0	Yes 0 2026-07-18..
CI-874205	mc-runner-az-05	ubuntu-22.04	1	05:58	734	1.68.0	Yes 0 2026-07-18..
CI-874209	mc-runner-az-11	ubuntu-22.04	1	06:03	701	1.68.0	Yes 0 2026-07-18..
CI-874212	mc-runner-az-03	ubuntu-22.04	1	06:27	689	1.68.0	Yes 0 2026-07-18..
CI-874214	mc-runner-az-15	ubuntu-22.04	1	07:14	826	1.68.0	Yes 0 2026-07-18..
CI-874218	mc-runner-az-08	ubuntu-22.04	1	04:51	618	1.68.0	Yes 0 2026-07-18..
CI-874220	mc-runner-az-20	ubuntu-22.04	1	04:37	605	1.68.0	Yes 0 2026-07-18..

CI-874223	mc-runner-az-02	ubuntu-22.04	1	06:12	741	1.68.0	Yes 0 2026-07-18..

Meridian Capital -- SAST/DAST Security Scan Report -- Sprint 42

Page 8: Rule Governance, Non-Actionable Patterns, and Onboarding Status

This page documents rule governance changes effective in Sprint 42, representative non-actionable pattern detections for transparency, and repository onboarding/health status. Updates were routine, with no impact to security posture. All communications and approvals are tracked via change tickets.

Table 8.1 -- Rule Governance Change Log (Sprint 42)

Change ID	Effective Date (U..	Rule/Pack	Change Type	Rationale	Owner Team	Approval Ticket	Impacted Repos ..
RG-042-001	2026-07-16T14:00:..	mc-semgrep-pack ..	Pack upgrade	Monthly cadence; r..	AppSec Engineeri..	SEC-42131	All ChCom-2330
RG-042-002	2026-07-16T14:05:..	MC_COMMENTS_..	Tuning: threshold ..	Reduce noise; bac..	AppSec Engineeri..	SEC-42134	core-payments-api..
RG-042-003	2026-07-16T14:10:..	MC_TS_ANY_GE..	Suppress in /src/g..	Generated code; ..	AppSec Engineeri..	SEC-42138	onboarding-portal ..
RG-042-004	2026-07-16T14:12:..	MC_FORMAT_TR..	Delegate to formatt..	Ownership clarity ..	Developer Experie..	DX-3109	quant-research-infr..
RG-042-005	2026-07-16T14:15:..	MC_DOC_HEADE..	Clarify SPDX varia..	Accept 2026 SPD..	Compliance Eng	CMP-1992	treasury-risk-mode..
RG-042-006	2026-07-16T14:20:..	MC_JSON_DUP_..	Document last-win..	Allow explicit overri..	Cloud Platform En..	CPE-7730	infra-pipelines ChC..
RG-042-007	2026-07-16T14:24:..	MC_LOG_PLACE..	Add tag: observabi..	Improve filtering/re..	AppSec Engineeri..	SEC-42142	analytics-ingestion ..
RG-042-008	2026-07-16T14:30:..	MC_NAMING_CO..	Normalize rule na..	Align with style-gui..	Developer Experie..	DX-3112	core-ledger ChCo..
RG-042-009	2026-07-16T14:35:..	MC_TEST_IGNOR..	Add rationale capt..	Encourage context..	Quality Engineering	QA-21470	onboarding-portal, ..
RG-042-010	2026-07-16T14:40:..	MC_SQL_FMT_016	Cross-link to sqlfmt..	Documentation link..	Data Engineering	DE-4401	treasury-risk-mode..

Table 8.2 -- Representative Non-Actionable Pattern Detections

Sample ID	Repository	Pattern	Instances	Status	Comment
NA-042-001	digital-banking-app	TODO comments in n..	14	Tracked via hygiene e..	Consolidated under UI..
NA-042-002	analytics-ingestion	Console/logging in tes..	9	Expected in test scope	Covered by jest env; n..
NA-042-003	core-payments-api	String interpolation log..	6	Conforms to standard	Verified structured fiel..
NA-042-004	treasury-risk-models	Unused imports flagge..	7	Delegated to linter	flake8 auto-enforced i..
NA-042-005	onboarding-portal	any type in generated ..	12	Excluded by path	Generated from Open..
NA-042-006	core-ledger	Deprecated build scrip..	2	Documented legacy	Retained as comment ..
NA-042-007	quant-research-infra	Trailing whitespace	11	Auto-corrected	Pre-commit hook appli..
NA-042-008	infra-pipelines	Duplicate YAML keys ..	3	Known last-wins	Intentional environme..
NA-042-009	digital-banking-app	Unreferenced i18n keys	4	Clean-up scheduled	Removal included in s..
NA-042-010	treasury-risk-models	SQL formatting nonsta..	5	Formatter-owned	sqlfmt applied; Semgr..
NA-042-011	analytics-ingestion	Schema missing optio..	3	Accepted variance	Coverage remains ab..
NA-042-012	core-payments-api	Test naming variance	8	Hygiene backlog	Folded into CP-HE-42.

Table 8.3 -- Repository Onboarding and Health Checklist

Repository	Semgrep CI Integ..	Policy Bundle Sy..	Baseline Establis..	Alert Channel	Maintainers Confi..	Last Health Revie..	Next Action
core-payments-api	Enabled	2026-07-16T13:00:..	2026-06-05	#core-payments-sec	5/5	2026-07-17T10:22:..	Quarterly review 2..
digital-banking-app	Enabled	2026-07-16T13:05:..	2026-06-07	#digital-banking-sec	6/6	2026-07-17T10:31:..	Migrate to pack 20..
treasury-risk-models	Enabled	2026-07-16T13:10:..	2026-06-01	#risk-analytics-sec	4/4	2026-07-17T10:15:..	Add data lineage t..
analytics-ingestion	Enabled	2026-07-16T13:15:..	2026-06-03	#data-eng-sec	5/5	2026-07-17T10:18:..	Align repo ignore ..
onboarding-portal	Enabled	2026-07-16T13:20:..	2026-06-02	#onboarding-sec	4/4	2026-07-17T10:26:..	Confirm @ignore r..
core-ledger	Enabled	2026-07-16T13:25:..	2026-06-04	#finance-systems-..	3/3	2026-07-17T10:28:..	Merge style-guide ..
quant-research-infra	Enabled	2026-07-16T13:30:..	2026-06-06	#quant-sec	3/3	2026-07-17T10:12:..	Add notebook excl..
infra-pipelines	Enabled	2026-07-16T13:35:..	2026-06-08	#platform-sec	4/4	2026-07-17T10:20:..	Document override..

Table 8.4 -- Tag Distribution and Rule Utilization (Informational Categories)

Tag	Description	Rules Tagged	Hits (Sprint 42)	Primary Repos	Notes
observability	Logging and metrics p..	12	41	analytics-ingestion, co..	New tag added in RG-..
style	Formatting and naming	28	57	core-ledger, digital-ba..	Ownership moved to ..
docs	Headers and comments	9	23	treasury-risk-models	SPDX clarifications re..
generated	Generated-code allow..	6	20	onboarding-portal	Exclusion path confirm..
tests	Test-scope patterns	15	33	digital-banking-app, o..	Expected density due ..
config	YAML/JSON structure	8	16	infra-pipelines	Last-wins comment pr..

Summary: Governance updates focused on clarity, ownership, and noise reduction within informational and maintainability categories. All repositories remain fully integrated with Semgrep CI, with baseline comparisons established and alerting affirmed. No action items pertain to risk remediation; next-cycle tasks are administrative (rule pack roll-forward, documentation linkages, and minor hygiene consolidation).

SAST/DAST Security Scan Report -- Sprint 42

Meridian Capital

Pages 9-10

Page 9 -- Semgrep SAST Coverage and Benign Outcomes Summary

During Sprint 42, the Semgrep SAST pipeline executed against target microservices across the Core Banking, Payments, Risk, and Platform portfolios. Scans ran under the standard meridian-baseline@2026.07 and service-specific overlays, with engine 1.88.2 deployed across all CI agents. All executions completed successfully with no actionable security defects. Informational notices were logged for traceability (e.g., maintainability, explicit encoding declarations, log structure conformance), and have been recorded to the tracker for routine backlog grooming. Timing, scale, and reviewer metadata are provided below to support auditability and reproducibility. No policy exceptions were requested or granted in this sprint cycle.

Service-level SAST Execution Summary -- Sprint 42 (Benign Outcomes)

Service / Compon..	Repo Slug	Commit SHA	CI Job ID	Ruleset	Engine	Files Scanned	Lines Analyzed R..
core-banking-ledger	github.com/meridia..	9f3a7b1	gh-18294721	meridian-baseline..	1.88.2	412	128,943 1,284 2 1,..
payments-gateway	github.com/meridia..	d2ab31f	gh-18295109	payments-overlay..	1.88.2	356	95,604 1,167 1 1,1..
risk-scoring-service	github.com/meridia..	a71c5d0	gh-18295544	analytics-quality@..	1.88.2	289	82,317 1,053 3 1,0..
client-onboarding-..	github.com/meridia..	4c6e9aa	gh-18295912	meridian-baseline..	1.88.2	221	64,108 927 2 925 ..
identity-access-ser..	github.com/meridia..	0b8f2e7	gh-18296277	web-hardening@2..	1.88.2	334	101,209 1,208 1 1,..
data-lake-ingest	github.com/meridia..	3dcd4c2	gh-18296690	analytics-quality@..	1.88.2	518	152,477 1,336 4 1,..
portfolio-analytics	github.com/meridia..	1a2f9bd	gh-18297111	analytics-quality@..	1.88.2	407	118,204 1,195 2 1,..
web-portal-ui	github.com/meridia..	8e17c44	gh-18297485	web-hardening@2..	1.88.2	623	176,592 1,421 3 1,..
mobile-gateway	github.com/meridia..	5f2a1cc	gh-18297933	web-hardening@2..	1.88.2	271	73,885 981 1 980 ..
partner-api	github.com/meridia..	af49e10	gh-18298302	meridian-baseline..	1.88.2	199	59,311 902 2 900 ..
settlement-engine	github.com/meridia..	b904c33	gh-18298671	payments-overlay..	1.88.2	344	110,225 1,171 2 1,..
alerts-notifications	github.com/meridia..	72c0aa1	gh-18299120	meridian-baseline..	1.88.2	178	48,907 843 1 842 ..
fee-calculator	github.com/meridia..	64e71da	gh-18299486	payments-overlay..	1.88.2	133	36,274 721 0 721 ..
report-scheduler	github.com/meridia..	29a44e9	gh-18299815	meridian-baseline..	1.88.2	267	77,180 996 1 995 ..
treasury-ops	github.com/meridia..	e81f0c8	gh-18300172	payments-overlay..	1.88.2	308	89,545 1,041 0 1,0..
statements-service	github.com/meridia..	90bb7f5	gh-18300731	meridian-baseline..	1.88.2	241	70,398 958 1 957 ..

Semgrep Rule Execution Metrics -- Top Rules by Execution Count (Informational Only)

Rule ID	Category	Severity	Evaluations	Matches	Files Touched	Avg Time (ms)	P95 Time (ms) St..
best-practice.no-to..	Maintainability	Informational	14,812	0	7,409	1.7	4.9 No Findings D..
style.explicit-encod..	Style	Informational	13,990	12	6,885	2.1	5.7 Benign Notice ..
observability.struct..	Observability	Informational	13,441	8	6,241	1.9	5.2 Benign Notice ..
compliance.audit.e..	Compliance	Informational	12,776	5	5,993	2.5	6.1 Benign Notice ..
maintainability.no-..	Maintainability	Informational	12,109	0	5,417	1.3	3.9 No Findings D..
docs.api-handler-h..	Documentation	Informational	11,845	14	5,310	1.6	4.1 Benign Notice ..
config.no-harcode..	Configuration	Informational	10,992	0	4,923	1.4	4.3 No Findings D..
testing.unit-test-na..	Quality	Informational	10,441	6	4,552	1.1	3.4 Benign Notice ..
dependency.licens..	Compliance	Informational	9,978	0	4,220	2.9	6.8 No Findings O..
serialization.explici..	Reliability	Informational	9,341	11	3,981	1.8	4.6 Benign Notice ..
secrets.false-positi..	Triage Hygiene	Informational	8,902	0	3,655	1.2	3.3 No Findings Ap..
i18n.user-facing-st..	Internationaliz.	Informational	8,517	7	3,411	2.0	5.1 Benign Notice ..
performance.no-sy..	Performance	Informational	7,933	0	3,090	1.5	4.0 No Findings Pl..
infra.ci-metadata-a..	Governance	Informational	7,501	9	2,941	1.0	3.2 Benign Notice ..
api.versioned-rout..	Governance	Informational	7,118	2	2,805	1.9	4.7 Benign Notice ..
logging.no-pii-plac..	Privacy	Informational	6,864	0	2,672	1.6	3.8 No Findings Pri..

Notes:

- "Benign Notice" indicates non-blocking informational output aligned with coding conventions and traceability objectives.
- Passed Checks equals evaluated rules minus benign notices, where applicable. No deviations from baseline thresholds were recorded.

Page 10 -- DAST Baseline Coverage and Stability (Non-Actionable)

The DAST baseline and safe active probe suite executed in lower environments to monitor regressions and confirm standard behavior. The sprint leveraged the "baseline-non-auth" and "baseline-auth" profiles with passive checks and non-invasive active probes. No actionable issues were identified. Variances versus Sprint 41 were limited to traffic volume and endpoint counts consistent with feature development and standard content changes. The team recorded informational observations (e.g., confirmatory headers present, JSON schema stability) solely for operational completeness. No policy exceptions were requested or granted; all scans satisfied SLA thresholds for completion, queue time, and data retention.

DAST Baseline Crawl & Probe Coverage -- Non-Auth and Auth Profiles (Benign)

Application	Env	Scan Profile	Run ID	Requests	Unique Endpoints	Auth Status	Passive Notices ..
web-portal-ui	UAT	baseline-non-auth	dast-431209	14,822	1,093	N/A	7 4 412 1.82 GB 2..
web-portal-ui	UAT	baseline-auth	dast-431210	12,405	847	OK	5 4 438 1.27 GB 2..
mobile-gateway	UAT	baseline-non-auth	dast-431221	9,114	603	N/A	3 3 387 864 MB 20..
partner-api	INT	baseline-auth	dast-431235	8,792	521	OK	2 3 401 776 MB 20..
payments-gateway	UAT	baseline-auth	dast-431244	10,109	642	OK	6 4 429 1.03 GB 2..
settlement-engine	INT	baseline-auth	dast-431251	6,587	411	OK	1 3 395 512 MB 20..
client-onboarding-..	INT	baseline-auth	dast-431263	7,944	488	OK	2 3 382 648 MB 20..
identity-access-ser..	UAT	baseline-auth	dast-431279	11,307	714	OK	4 4 441 1.11 GB 2..
partner-api	UAT	baseline-non-auth	dast-431288	5,210	339	N/A	1 2 364 401 MB 20..
portfolio-analytics	INT	baseline-non-auth	dast-431295	4,983	311	N/A	2 2 358 392 MB 20..
web-portal-ui	INT	baseline-non-auth	dast-431301	9,772	688	N/A	5 3 406 1.02 GB 2..
treasury-ops	UAT	baseline-auth	dast-431318	6,205	398	OK	1 3 372 518 MB 20..

Baseline Diff vs. Sprint 41 -- Non-Actionable Changes

Component	Metric	Sprint 41	Sprint 42	Delta	Interpretation	Action	Owner Team Log..
web-portal-ui	Unique Endpoints	1,041	1,093	+52	New marketing pa..	No action	Web Platform MC..
web-portal-ui	Passive Notices	9	7	-2	Header confirmatio..	No action	Web Platform MC..
payments-gateway	Requests	9,541	10,109	+568	Additional routes in..	No action	Payments & Treas..
identity-access-ser..	p95 Resp (ms)	452	441	-11	Improved cache eff..	Monitor only	Identity Platform M..
partner-api	Unique Endpoints	847	860	+13	Partner v2 pilot tog..	No action	Partner Engineerin..
client-onboarding-..	Passive Notices	3	2	-1	Harmonized log ke..	No action	Client Onboarding ..
portfolio-analytics	Requests	4,511	4,983	+472	Expanded dashbo..	No action	Data & Analytics M..
settlement-engine	Bytes Transferred	486 MB	512 MB	+26 MB	More sample paylo..	No action	Payments & Treas..
mobile-gateway	p95 Resp (ms)	391	387	-4	CDN edge warm-up	Monitor only	Mobile Platform M..
treasury-ops	Unique Endpoints	389	398	+9	Routine feature inc..	No action	Treasury Ops MC..
web-portal-ui	Requests	26,105	27,227	+1,122	Broader crawl see..	No action	Web Platform MC..
partner-api	Passive Notices	3	3	0	Stable baseline	No action	Partner Engineerin..

Scanner Health & SLA Metrics -- Sprint 42

Metric	Target	Actual	Status	Notes	Owner	Reviewed (UTC)
Scan Queue Time ..	<= 10m	6m 42s	Met	Ample runner capa..	DevSecOps Platfo..	2026-07-22T19:05..
Scan Duration (ba..	<= 35m	27m 14s	Met	Optimized crawl se..	DevSecOps Platfo..	2026-07-22T19:05..
Completion Rate	100%	100%	Met	No timeouts or can..	Application Security	2026-07-22T19:05..
Result Retention (..	>= 14d	21d	Exceeds	Retention window ..	Security Operations	2026-07-22T19:05..
Auth Session Reu..	0	0	Met	Session injectors s..	AppSec Tooling	2026-07-22T19:05..
Data Masking in H..	100%	100%	Met	Verified by automa..	Privacy Engineering	2026-07-22T19:05..
Engine Version Pa..	1.88.2	1.88.2	Met	All agents synchro..	DevSecOps Platfo..	2026-07-22T19:05..

Policy Exceptions ..	0	0	Met	None requested; n..	Governance & Risk	2026-07-22T19:05..

Notes:

- Passive Notices represent confirmatory observations captured by the baseline profiles (e.g., standard headers present, JSON content type alignment).
- All DAST activities remained within non-invasive bounds. No attack payloads or destructive probes were utilized in baseline profiles.
- The scan fleet's utilization averaged 62% during peak window, leaving headroom for ad-hoc validations without SLA impact.

Page 11 -- Benign Match Review Log (Semgrep SAST) -- Sprint 42

During Sprint 42, Meridian Capital's AppSec Operations completed a structured review of all semgrep SAST matches that were automatically triaged as informational or non-actionable. The entries below reflect routine hygiene checks, rule verifications, and context-confirmed benign conditions. All items were dispositioned in alignment with standard operating criteria and closed with rationale for audit completeness. No corrective code changes were required as all matches were classified benign or compliant.

Ticket	Repo/Service	Rule ID	Category	Severity	Status	Disposition Ratio..	File Path Line Co..
MCSEC-7421	payments-service	java.logging.place..	Logging	Info	Closed -- Benign	Placeholder count ..	src/main/java/com/..
MCSEC-7422	client-portal	js.react.safe-prop-..	Code Hygiene	Info	Closed -- Not Appli..	Component prop c..	ui/components/He..
MCSEC-7423	risk-engine	python.requests.ti..	Reliability	Info	Closed -- Compliant	Explicit timeout pre..	risk/api/ingest.py 2..
MCSEC-7424	data-pipeline	general.todo.com..	Testing	Info	Closed -- Allowliste..	TODO appears un..	tests/helpers/fakes..
MCSEC-7425	payments-service	java.serialization.s..	Serialization	Info	Closed -- Compliant	serialVersionUID d..	src/main/java/com/..
MCSEC-7426	client-portal	css.content-no-dyn..	UI Hygiene	Info	Closed -- Benign	Static content strin..	ui/styles/modal.css..
MCSEC-7427	risk-engine	python.logging.exi..	Logging	Info	Closed -- Benign	Existing module lo..	risk/utils/log.py 52 ..
MCSEC-7428	data-pipeline	yaml.key-order-co..	Config	Info	Closed -- Compliant	Keys ordered per b..	conf/pipeline.yml 9..
MCSEC-7429	payments-service	java.spring.nonnull..	Defensive Coding	Info	Closed -- Compliant	@NonNull present ..	src/main/java/com/..
MCSEC-7430	client-portal	js.string-template-s..	Code Hygiene	Info	Closed -- Benign	Template literal wit..	ui/utils/format.js 41..
MCSEC-7431	risk-engine	python.dict.get-wit..	Defensive Coding	Info	Closed -- Compliant	Default provided in..	risk/metrics/rollup...
MCSEC-7432	data-pipeline	bash.set-eu-pipefai..	Reliability	Info	Closed -- Compliant	set -euo pipefail pr..	scripts/deploy.sh 5..
MCSEC-7433	payments-service	java.streams.nulls..	Defensive Coding	Info	Closed -- Benign	Optional.orElse us..	src/main/java/com/..
MCSEC-7434	client-portal	ts.enum-exhaustiv..	Code Hygiene	Info	Closed -- Compliant	Switch statements ..	ui/pages/Account.t..
MCSEC-7435	risk-engine	python.dataclass.fr..	Defensive Coding	Info	Closed -- Compliant	@dataclass(frozen..	risk/models/payloa..
MCSEC-7436	data-pipeline	sql.parameterized-..	Compliance	Info	Closed -- Compliant	Parameterization c..	jobs/loaders/redshi..
MCSEC-7437	payments-service	java.httpclient.time..	Reliability	Info	Closed -- Compliant	Connection and re..	src/main/java/com/..
MCSEC-7438	client-portal	react.memo-usage	Performance	Info	Closed -- Benign	Memoization appli..	ui/components/Bal..
MCSEC-7439	risk-engine	python.with-resour..	Resource Mgmt	Info	Closed -- Compliant	Context manager c..	risk/io/reader.py 36..
MCSEC-7440	data-pipeline	airflow.task-id-con..	Standards	Info	Closed -- Compliant	Task IDs align to n..	dags/settlements_..
MCSEC-7441	payments-service	java.slf4j.paramete..	Logging	Info	Closed -- Compliant	Parameterized log..	src/main/java/com/..
MCSEC-7442	client-portal	ts.optional-chainin..	Defensive Coding	Info	Closed -- Benign	Optional chaining ..	ui/utils/session.ts 5..
MCSEC-7443	risk-engine	python.logging.no-f..	Logging	Info	Closed -- Compliant	Lazy logger args u..	risk/core/executor...
MCSEC-7444	data-pipeline	yaml.anchor-usage..	Config	Info	Closed -- Benign	YAML anchors use..	conf/environments/..

All reviewed entries have been documented in the sprint audit trail and linked to their respective repository PRs where applicable. No further action pending.

Page 12 -- Scan Execution Metrics and Configuration -- Sprint 42

This page summarizes the operational aspects of semgrep SAST execution during Sprint 42, including run metadata, coverage distribution, and ignore list governance. All service-level objectives were met. No deviations from the approved rule packs were detected, and all informational matches were handled per the standard review cadence.

Scan Execution Summary (All Nightly and On-Demand Runs)

Scan ID	Repo	Branch	Trigger	Start Time	End Time	Duration	Semgrep Version ..
S42-001	payments-service	main	Nightly	2026-07-18T01:10:..	2026-07-18T01:12:..	00:02:24	1.61.0 mc-appsec:..
S42-002	client-portal	develop	Nightly	2026-07-18T01:15:..	2026-07-18T01:19:..	00:03:18	1.61.0 mc-ui:2.3 3..
S42-003	risk-engine	main	Nightly	2026-07-18T01:22:..	2026-07-18T01:23:..	00:01:43	1.61.0 mc-analytic..
S42-004	data-pipeline	release/2.4	Nightly	2026-07-18T01:25:..	2026-07-18T01:27:..	00:02:43	1.61.0 mc-data:3.4..
S42-005	payments-service	feature/settlements..	On-Demand	2026-07-19T14:33:..	2026-07-19T14:36:..	00:02:14	1.61.0 mc-appsec:..
S42-006	client-portal	release/1.12	Nightly	2026-07-19T01:11:..	2026-07-19T01:15:..	00:03:07	1.61.0 mc-ui:2.3 3..
S42-007	risk-engine	hotfix/pricing	On-Demand	2026-07-20T09:08:..	2026-07-20T09:09:..	00:01:24	1.61.0 mc-analytic..
S42-008	data-pipeline	main	Nightly	2026-07-20T01:20:..	2026-07-20T01:22:..	00:02:22	1.61.0 mc-data:3.4..
S42-009	payments-service	main	Nightly	2026-07-21T01:09:..	2026-07-21T01:12:..	00:02:21	1.61.0 mc-appsec:..
S42-010	client-portal	develop	Nightly	2026-07-21T01:15:..	2026-07-21T01:18:..	00:03:18	1.61.0 mc-ui:2.3 3..

Rule Coverage and Match Distribution (Informational/Compliant Only)

Rule Family	Rule ID	Description	Files Scanned	Matches	Disposition	Coverage %	Notes
Logging	java.slf4j.paramete..	Parameterized log..	142	11	Compliant	100	Confirmed across ..
Logging	python.logging.exi..	Use of module-lev..	97	7	Benign	100	No duplicate handl..
Defensive Coding	java.spring.nonnull..	Non-null annotatio..	86	8	Compliant	98	Minor internal-only ..
Defensive Coding	python.dict.get-wit..	Default provided in..	65	6	Compliant	100	Util modules cover..
Reliability	python.requests.ti..	Explicit timeouts o..	44	5	Compliant	100	Matches align with ..
Reliability	java.httpclient.time..	Client timeouts con..	51	4	Compliant	100	Centralized HTTP f..
Config	yaml.key-order-co..	Ordered keys per s..	39	6	Compliant	100	Schema validator c..
Config	yaml.anchor-usage..	YAML anchors use..	22	3	Benign	100	Readability improv..
Serialization	java.serialization.s..	serialVersionUID p..	28	4	Compliant	100	All DTOs aligned
UI Hygiene	js.string-template-s..	Static template liter..	57	3	Benign	100	No interpolation so..
UI Hygiene	css.content-no-dyn..	Static CSS content..	19	2	Benign	100	Cosmetic
Performance	react.memo-usage	Memoized function..	34	2	Benign	100	Intentional optimiz..
Standards	airflow.task-id-con..	Task ID naming co..	16	2	Compliant	100	DAGs pass lint gat..
Resource Mgmt	python.with-resour..	Use of context ma..	41	3	Compliant	100	Files and sockets c..
Testing	general.todo.com..	TODO markers in t..	73	9	Allowlisted (Tests)	100	Matches under test..
Compliance	sql.parameterized-..	Parameterized SQ..	12	2	Compliant	100	Vendor driver-bou..

Suppression and Ignore Governance (Benign/Structural Only)

Entry ID	Repo	Path Pattern	Rule ID	Added By	Added On	Expiration	Scope Review Tic..
IG-0221	client-portal	ui//__mocks__/	general.todo.com..	L. Harper	2026-07-18T10:22:..	2026-10-01	Directory MCSEC-..
IG-0222	data-pipeline	dags//generated/	yaml.key-order-co..	K. Lin	2026-07-18T12:01:..	2026-12-31	Directory MCSEC-..
IG-0223	risk-engine	risk//schemas/	python.dict.get-wit..	T. Nguyen	2026-07-19T08:44:..	2026-09-30	Directory MCSEC-..
IG-0224	payments-service	src//autogen/	java.serialization.s..	M. Chen	2026-07-19T14:17:..	2026-10-15	Directory MCSEC-..
IG-0225	client-portal	ui/styles/**	css.content-no-dyn..	J. Gallagher	2026-07-20T09:09:..	2026-11-30	Directory MCSEC-..
IG-0226	data-pipeline	conf//examples/	yaml.anchor-usage..	K. Lin	2026-07-20T10:33:..	2026-09-01	Directory MCSEC-..
IG-0227	risk-engine	tests/**	python.logging.exi..	S. Rao	2026-07-21T07:51:..	2026-12-01	Directory MCSEC-..
IG-0228	payments-service	src//legacy/	java.slf4j.paramete..	M. Chen	2026-07-21T12:19:..	2026-10-31	Directory MCSEC-..
IG-0229	client-portal	ui//stories/	react.memo-usage	L. Harper	2026-07-21T13:05:..	2026-12-31	Directory MCSEC-..
IG-0230	data-pipeline	scripts/**	bash.set-eu-pipefai..	K. Lin	2026-07-21T14:22:..	2026-09-30	Directory MCSEC-..

Team Acknowledgements and SLA Tracking (Informational Queue)

Ticket	Team	Ack Type	Count	SLA Met	Last Updated	Notes
MCSEC-742x	Core Banking	Benign Review Ac..	9	Yes	2026-07-21T15:01..	Within 2-business-..
MCSEC-742x	Digital Channels	Benign Review Ac..	8	Yes	2026-07-21T12:45..	Batched with UI re..
MCSEC-742x	Risk Analytics	Benign Review Ac..	7	Yes	2026-07-21T10:19..	Completed before ..
MCSEC-742x	Data Platform	Benign Review Ac..	6	Yes	2026-07-20T16:33..	Coordinated with ..

All runs executed within configured SLAs, and all benign matches were dispositioned without escalation. No follow-ups required for Sprint 42.

Page 13 -- Semgrep Benign Match Review and Metrics (Sprint 42)

The following records summarize triaged semgrep matches classified as benign or informational during Sprint 42. Reviews were jointly performed by Application Security Engineering and service teams to maintain scan quality and reduce alert fatigue without impacting coverage. All entries below are routine operational items confirming expected patterns, generated code, test scaffolding, or framework-standard idioms.

Finding ID	Rule ID	Rule Title	Severity	Classification	Repo/Service	File (relative)	Lines Matched P..
FND-13-001	mc.java.logging.for..	Logging format pla..	Informational	Benign (framework..	retail-ledger-service	src/main/java/com/..	4 PR-1845 N. Josh..
FND-13-002	mc.ts.redux.action-..	Redux action shap..	Low	Benign (UI convent..	client-portal-ui	src/store/actions/s..	2 PR-731 E. Varga..
FND-13-003	mc.py.dataclass.init	Dataclass repr/init ..	Informational	Benign (generated ..	treasury-ops	treasury/config/mo..	3 MR-508 C. Duon..
FND-13-004	mc.cs.nullcheck.pa..	Redundant null-ch..	Informational	Benign (defensive ..	wealth-trading-api	Services/TradeCo..	5 PR-2190 J. Patel..
FND-13-005	mc.java.optionals...	Optional.orElseGet..	Informational	Benign (performan..	risk-analytics	src/main/java/com/..	2 PR-1107 L. Rom..
FND-13-006	mc.yaml.k8s.annot..	Kubernetes annota..	Informational	Benign (infra meta..	platform-infra	k8s/rbac/role.yaml	6 MR-912 P. Sriniv..
FND-13-007	mc.go.errwrap.style	Go error wrapping ..	Low	Benign (team stan..	payments-gateway	pkg/settlement/wor..	3 PR-876 B. Reye..
FND-13-008	mc.sql.migration.c..	Migration comment..	Informational	Benign (docstring)	credit-core	db/migrations/2026..	1 PR-562 S. Li Ap..
FND-13-009	mc.kotlin.coroutine..	Coroutine scope d..	Informational	Benign (structured ..	mobile-banking-an..	app/src/main/kotlin..	2 MR-332 H. Park ..
FND-13-010	mc.ruby.symbol.to..	Symbol-to-proc sh..	Informational	Benign (idiomatic)	wealth-rails-portal	app/services/audit..	1 PR-204 G. Almei..
FND-13-011	mc.scala.cats.eithe..	EitherT mapping p..	Informational	Benign (library usa..	quant-reports	src/main/scala/co..	4 PR-97 D. Novak ..
FND-13-012	mc.ts.non-null.ass..	Non-null assertion ..	Low	Benign (test scaffol..	client-portal-ui	src/test/mocks/use..	3 PR-745 K. Ahme..
FND-13-013	mc.java.lombok.ge..	Lombok getter usa..	Informational	Benign (codegen)	retail-ledger-service	src/main/java/com/..	2 PR-1852 R. Che..
FND-13-014	mc.py.logging.ada..	Logging adapter p..	Informational	Benign (adapter co..	treasury-ops	treasury/logging/ad..	5 MR-519 M. Sing..
FND-13-015	mc.cs.linq.query-s..	LINQ query syntax..	Informational	Benign (style guide)	wealth-trading-api	Services/Positions..	2 PR-2198 J. Patel..
FND-13-016	mc.go.context.pass	Context propagation	Informational	Benign (expected)	payments-gateway	internal/queue/con..	3 PR-889 B. Reye..
FND-13-017	mc.sql.param.mark..	Parameter marker ..	Informational	Benign (ORM-man..	credit-core	src/main/java/com/..	1 PR-571 S. Li Ap..
FND-13-018	mc.yaml.helm.tpl	Helm template fun..	Informational	Benign (chart logic)	platform-infra	helm/charts/ingres..	4 MR-926 P. Sriniv..
FND-13-019	mc.kotlin.sealed.w..	When over sealed ..	Informational	Benign (compile-c..	mobile-banking-an..	app/src/main/kotlin..	1 MR-338 H. Park ..
FND-13-020	mc.ruby.safe-navig..	Safe navigation op..	Informational	Benign (nil-safe)	wealth-rails-portal	app/controllers/pos..	2 PR-211 G. Almei..

Semgrep suppression annotations were applied where appropriate to minimize recurring noise from known benign patterns. All suppressions below have linked tracking tickets and review ownership; no policy deviations were required.

Suppression ID	Rule ID	Repo	File	Reason Code	Reason Summary	Expiration	Annotated By Ap..
SUP-13-001	mc.ts.non-null.ass..	client-portal-ui	src/test/mocks/use..	FP-KNOWN-PATT..	Test-only assertion..	2027-01-15	K. Ahmed N. Joshi..
SUP-13-002	mc.java.logging.for..	retail-ledger-service	src/main/java/com/..	EXPECTED-FOR..	Framework-specifi..	2026-12-31	R. Chen C. Duong ..
SUP-13-003	mc.go.errwrap.style	payments-gateway	pkg/settlement/wor..	STYLE-ALLOW	Team-sanctioned ..	2026-11-30	B. Reyes P. Sriniv..
SUP-13-004	mc.yaml.k8s.annot..	platform-infra	k8s/rbac/role.yaml	META-ONLY	Metadata annotati..	2026-10-01	P. Srinivasan L. R..
SUP-13-005	mc.cs.nullcheck.pa..	wealth-trading-api	Services/TradeCo..	DEFENSIVE-OK	Defensive check re..	2027-03-31	J. Patel G. Almeid..
SUP-13-006	mc.scala.cats.eithe..	quant-reports	src/main/scala/co..	LIB-USAGE	Functional-lib idio..	2027-06-30	D. Novak M. Singh..
SUP-13-007	mc.sql.param.mark..	credit-core	src/main/java/com/..	ORM-MANAGED	ORM ensures para..	2026-12-15	S. Li N. Joshi MC-..
SUP-13-008	mc.kotlin.coroutine..	mobile-banking-an..	app/src/main/kotlin..	SCOPE-STANDA..	Standard lifecycle-..	2026-12-31	H. Park E. Vargas ..
SUP-13-009	mc.ruby.symbol.to..	wealth-rails-portal	app/services/audit..	IDIOM-OK	Idiomatic shorthan..	2027-04-30	G. Almeida C. Duo..
SUP-13-010	mc.yaml.helm.tpl	platform-infra	helm/charts/ingres..	TEMPLATE-OK	Helm helper templ..	2026-12-01	P. Srinivasan L. R..

Rule execution performance was tracked to validate CI timing targets and assess cache effectiveness. Metrics below reflect the mid-sprint snapshot from the Meridian Capital shared CI runners.

Rule ID	Rule Title	Runs (Sprint 42)	Avg Runtime (ms)	P95 Runtime (ms)	Matches (Info)	Suppressions Act..	Repos Affected E..
mc.java.logging.for..	Logging format pla..	118	42	77	36	1	3 semgrep 1.67.0 ..
mc.ts.redux.action-..	Redux action shap..	64	53	91	12	0	1 semgrep 1.67.0 ..
mc.py.dataclass.init	Dataclass repr/init ..	41	36	63	8	0	1 semgrep 1.67.0 ..
mc.cs.nullcheck.pa..	Redundant null-ch..	72	48	88	14	1	1 semgrep 1.67.0 ..
mc.java.optionals...	Optional.orElseGet..	58	39	70	11	0	1 semgrep 1.67.0 ..
mc.yaml.k8s.annot..	Kubernetes annota..	97	34	59	27	1	1 semgrep 1.67.0 ..
mc.go.errwrap.style	Go error wrapping ..	55	31	51	9	1	1 semgrep 1.67.0 ..

mc.sql.migration.c..	Migration comment..	23	21	38	3	0	1 semgrep 1.67.0 ..
mc.kotlin.coroutine..	Coroutine scope d..	35	29	47	6	1	1 semgrep 1.67.0 ..
mc.ruby.symbol.to..	Symbol-to-proc sh..	19	26	43	2	1	1 semgrep 1.67.0 ..
mc.scala.cats.eithe..	EitherT mapping p..	12	33	52	2	1	1 semgrep 1.67.0 ..
mc.ts.non-null.ass..	Non-null assertion ..	61	28	45	18	1	1 semgrep 1.67.0 ..

Page 14 -- Coverage, Consistency, and Follow-Up (Sprint 42)

This page consolidates cross-repository coverage metrics, CI timing, and informational follow-ups opened during Sprint 42. The focus remains on ensuring stable semgrep execution across services with consistent rule behavior, steady cache performance, and traceable ownership of benign classifications.

Repo/Service	Default Branch	Head Commit	Files Scanned	LOC Scanned	Rules Executed	Matches (Info)	Scan Duration Ca..
retail-ledger-service	main	8f3c1a7	1,284	142,110	146	7	3m 42s 85% 1.67...
client-portal-ui	main	c1a9e02	2,417	198,552	132	14	4m 05s 80% 1.67...
treasury-ops	develop	44be6d0	723	67,485	119	8	2m 11s 82% 1.67...
wealth-trading-api	master	0d9f2b3	1,106	124,900	138	6	3m 26s 81% 1.67...
payments-gateway	main	33bd71e	902	88,764	127	5	2m 54s 79% 1.67...
credit-core	release/3.8	7a0cd15	1,349	151,203	141	4	3m 49s 86% 1.67...
platform-infra	main	1e5f0c9	488	52,117	98	10	1m 58s 88% 1.67...
mobile-banking-an..	develop	2a9e8d1	1,950	176,004	125	3	3m 37s 78% 1.67...
wealth-rails-portal	main	6d77b42	811	73,420	116	3	2m 06s 87% 1.67...
quant-reports	main	e91b0fa	364	41,893	92	2	1m 41s 83% 1.67...
risk-analytics	feature/cache-v2	55a1de8	629	69,578	121	5	2m 37s 82% 1.67...
treasury-ops (night..	nightly	9b0c1ae	723	67,485	119	8	2m 07s 90% 1.67...

Cross-team informational follow-ups were logged to track documentation alignment, suppression audits, and minor configuration harmonization. These items are non-blocking and intended to maintain consistency across Sprint 43.

Action ID	Summary	Owner Team	Primary Repo	Status	Target Sprint	Jira/Ticket	Opened (UTC) La..
ACT-14-001	Document defensi..	Wealth Eng	wealth-trading-api	Scheduled	43	MC-WE-2005	2026-07-20T09:30:..
ACT-14-002	Consolidate loggin..	AppSec Eng	retail-ledger-service	In Review	43	MC-SEC-6278	2026-07-19T10:25:..
ACT-14-003	Helm template ann..	DevSecOps	platform-infra	Scheduled	43	MC-PLAT-3315	2026-07-22T12:31:..
ACT-14-004	Redux action shap..	Digital Channels	client-portal-ui	In Progress	43	MC-DC-2431	2026-07-21T14:12:..
ACT-14-005	ORM parameteriza..	AppSec Eng	credit-core	Completed	42	MC-SEC-6272	2026-07-22T11:06:..
ACT-14-006	Go error wrapping ..	Payments Eng	payments-gateway	Scheduled	43	MC-PAY-1463	2026-07-20T16:55:..
ACT-14-007	Data class decorat..	Treasury Tech	treasury-ops	Completed	42	MC-TRE-1214	2026-07-20T08:07:..
ACT-14-008	Coroutines scope ..	Mobile Eng	mobile-banking-an..	In Review	43	MC-MOB-894	2026-07-22T14:02:..
ACT-14-009	Rails idioms quick ..	AppSec Eng	wealth-rails-portal	Scheduled	43	MC-SEC-6282	2026-07-21T10:36:..
ACT-14-010	Cats EitherT refere..	Quant Tech	quant-reports	Completed	42	MC-QR-520	2026-07-21T12:29:..
ACT-14-011	Semgrep cache tu..	DevSecOps	shared-ci	In Review	43	MC-PLAT-3318	2026-07-22T09:41:..
ACT-14-012	Rule naming norm..	AppSec Eng	rules-internal	In Progress	43	MC-SEC-6285	2026-07-22T15:20:..

Rule stability and consistency were reviewed against historical data to confirm predictable behavior and low churn in benign classifications. No anomalies were observed, and runtime variability remained within expected thresholds for shared runners.

Rule ID	Stability Score (0-..	Match Variance (..	CI Flake Rate	Last Regression ..	Consistency Notes	Monitoring Ticket
mc.java.logging.for..	98	+1.2%	0.0%	2026-05-03	Stable across Java..	MC-SEC-6120
mc.ts.redux.action-..	95	+2.8%	0.0%	2026-06-12	Minor fluctuation d..	MC-DC-2370
mc.py.dataclass.init	97	+0.5%	0.0%	2026-04-28	Generated pattern..	MC-SEC-6067
mc.cs.nullcheck.pa..	93	+3.4%	0.0%	2026-05-21	Defensive style var..	MC-WE-1952
mc.java.optionals...	96	+0.9%	0.0%	2026-05-15	Usage concentrate..	MC-SEC-6081
mc.yaml.k8s.annot..	99	+0.3%	0.0%	2026-06-01	Very stable; annot..	MC-PLAT-3290
mc.go.errwrap.style	94	+1.7%	0.0%	2026-05-27	Style consistent; m..	MC-PAY-1442
mc.sql.migration.c..	97	+0.0%	0.0%	2026-03-10	Nightly cadence dr..	MC-SEC-6009
mc.kotlin.coroutine..	92	+2.1%	0.0%	2026-06-07	Growth aligned wit..	MC-MOB-872
mc.ruby.symbol.to..	96	+0.4%	0.0%	2026-04-19	Idiomatic usage lo..	MC-SEC-6079

mc.scala.cats.eith..	95	+1.0%	0.0%	2026-05-09	Concentrated in re..	MC-QR-501
mc.ts.non-null.ass..	93	+2.9%	0.0%	2026-06-18	Test growth increa..	MC-DC-2381

Summary for Pages 13-14: Benign findings and informational matches were reviewed and, where appropriate, suppressed with clear traceability and ownership. Execution metrics remain within SLA, with cache hit rates between 78-90% and stable engine versioning across CI. Follow-up tasks are procedural in nature, reinforcing documentation and naming consistency ahead of Sprint 43 scopes.

Page 15 -- SAST rule tuning and informational reviews (Semgrep), Sprint 42

This section documents Semgrep rule adjustments and informational observations completed during Sprint 42 for Meridian Capital. Items recorded here are non-security-impacting and reflect operational tuning, categorization alignment, and housekeeping reviews to maintain high signal-to-noise across CI pipelines. All changes were reviewed with AppSec Engineering and the respective service teams and logged against standard tracking tickets for auditability.

Semgrep rule tuning register -- Sprint 42

Change ID	Rule ID	Rule title	Change type	Severity (before)	Severity (after)	Scope	Rationale summa..
RT-42-001	generic.deadcode...	Unused variable d..	Reclassify severity	Warning	Info	/src, exclude /tests	Reduce noise; hig..
RT-42-002	python.style.logger..	Prefer lazy logging..	Add path exclusion	Warning	Warning	exclude /migrations	ORM migrations g..
RT-42-003	java.bestpractice.o..	Use isPresent().ifP..	Reclassify severity	Warning	Info	/services/onboardi..	Advisory style guid..
RT-42-004	ts.maintainability.n..	console.log in prod..	Add environment g..	Warning	Warning	exclude NODE_E..	Allowable in test h..
RT-42-005	go.style.receiver-b..	Consistent receive..	Reclassify severity	Warning	Info	/go-services	Cosmetic refactor i..
RT-42-006	generic.logging.str..	Require structured ..	Narrow pattern	Warning	Warning	include /api, /jobs	Focus on externall..
RT-42-007	python.correctness..	Use == not "is" for ..	Path exclusion	Warning	Warning	exclude /tests	Common in test id..
RT-42-008	java.maintainability..	Magic numbers	Threshold tuned	Info	Info	/	Limit to >2 occurre..
RT-42-009	csharp.style.string-..	Prefer string interp..	Reclassify severity	Info	Info	/net-services	Aligns with style gu..
RT-42-010	python.bestpractic..	Prefer frozen datac..	Add rule enableme..	Off	Info	/shared/dto	Consistency with D..
RT-42-011	ts.correctness.awa..	Missing await on P..	Narrow pattern	Warning	Warning	exclude /scripts	Build tooling script..
RT-42-012	java.logging.slf4j-p..	Use parameterized..	Reclassify severity	Warning	Info	/services/*	Non-functional imp..
RT-42-013	go.bestpractice.co..	Pass context throu..	Scope expand	Info	Info	include /handlers	Improve observabil..
RT-42-014	python.maintainabi..	TODO/FIXME tag ..	Reclassify severity	Info	Info	/	No schedule implic..
RT-42-015	ts.style.prefer-nulli..	Prefer ?? over		for nullish	Enable	Off	Info /ui Align with T..
RT-42-016	python.imports.sort..	Imports should be ..	Path exclusion	Info	Info	exclude /generated	Generated code ch..
RT-42-017	java.tests.jupiter-a..	Prefer AssertJ/Jupi..	Scope narrow	Info	Info	include /tests	Standardize test fr..
RT-42-018	generic.docs.missi..	File missing licens..	Reclassify severity	Warning	Info	/	Administrative com..
RT-42-019	python.format.blac..	Enforce black form..	Enable	Off	Info	/python	Consistent formatti..
RT-42-020	ts.maintainability.u..	Unused jest snaps..	Enable	Off	Info	/ui/tests	Reduce stale asset..

Informational findings review log -- Sprint 42

Finding ID	Repository	File path	Rule ID	Summary	Status	Assignee	Opened Closed D..
IF-42-101	payments-api	src/handlers/refun..	go.style.receiver-b..	Mixed receiver styl..	Closed	S. Iyer	2026-07-11 2026-0..
IF-42-102	onboarding-svc	src/main/java/.../K..	java.logging.slf4j-p..	Concatenated log ..	Closed	L. Grayson	2026-07-11 2026-0..
IF-42-103	mobile-ui	ui/src/components/..	ts.style.prefer-nulli..	Use ?? over		for nullish	Closed H. Nguyen ..
IF-42-104	risk-analytics	py/analysis/score.py	python.correctness..	Identity compare to..	Closed	V. Kravtsov	2026-07-12 2026-0..
IF-42-105	data-pipeline	dags/transform.py	python.format.blac..	Formatting drift det..	Closed	J. Moreno	2026-07-13 2026-0..
IF-42-106	wealth-net	src/Portfolio.cs	csharp.style.string-..	String.Format usage	Closed	P. Shah	2026-07-13 2026-0..
IF-42-107	shared-dto	dto/account.py	python.bestpractic..	DTO not frozen	Closed	D. Park	2026-07-13 2026-0..
IF-42-108	onboarding-svc	src/test/java/.../Use..	java.tests.jupiter-a..	Mixed assertion libs	Closed	T. Brooks	2026-07-14 2026-0..
IF-42-109	payments-api	src/handlers/charg..	go.bestpractice.co..	Missing ctx propag..	Closed	M. Lewis	2026-07-14 2026-0..
IF-42-110	digital-ui	ui/src/utils/log.ts	generic.logging.str..	Non-structured log ..	Closed	M. Ruiz	2026-07-14 2026-0..
IF-42-111	data-pipeline	dags/load.py	python.imports.sort..	Imports out of order	Closed	J. Moreno	2026-07-14 2026-0..
IF-42-112	api-gateway	src/routes.js	ts.correctness.awa..	Missing await flagg..	Closed	H. Nguyen	2026-07-15 2026-0..
IF-42-113	wealth-net	src/Positions.cs	generic.docs.missi..	Header absent	Closed	E. Rossi	2026-07-15 2026-0..
IF-42-114	risk-analytics	py/utils/logging.py	generic.logging.str..	Missing required fi..	Closed	V. Kravtsov	2026-07-15 2026-0..
IF-42-115	platform-foundation	tools/format.sh	ts.maintainability.u..	Stale snapshot files	Closed	D. Park	2026-07-15 2026-0..
IF-42-116	mobile-ui	ui/src/hooks/usePo..	ts.maintainability.n..	console.log in dev-..	Closed	H. Nguyen	2026-07-16 2026-0..
IF-42-117	onboarding-svc	src/main/java/.../C..	java.maintainability..	Magic number in c..	Closed	L. Grayson	2026-07-16 2026-0..
IF-42-118	payments-api	src/dao/charge_da..	go.style.receiver-b..	Receiver mismatch	Closed	S. Iyer	2026-07-16 2026-0..
IF-42-119	data-pipeline	dags/archive.py	python.maintainabi..	TODO present	Closed	J. Moreno	2026-07-16 2026-0..
IF-42-120	api-gateway	src/logger.js	generic.logging.str..	Structured wrapper..	Closed	M. Ruiz	2026-07-17 2026-0..

Page 16 -- SAST coverage metrics and DAST session overview, Sprint 42

The following summarizes SAST scan coverage, pipeline performance, and DAST session telemetry for Sprint 42. All sessions completed within defined maintenance windows using synthetic accounts and non-privileged roles. Metrics are informational; no abnormal behavior or risk-significant conditions were observed.

SAST scan coverage matrix -- CI pipelines, Sprint 42

Repository	Languages	Ruleset version	Engine ver	Files scanned	LOC scanned	Exclusions	Duration (mm:ss)..
payments-api	Go	semgrep-std: 1.39.0	1.48.3	612	118,204	/tests, /vendor	07:42 4a8c2f1 CI-8..
onboarding-svc	Java	semgrep-std: 1.39.0	1.48.3	1,104	229,517	/generated, /tests	12:18 c3b79e9 CI-..
mobile-ui	TS/React	semgrep-std: 1.39.0	1.48.3	842	153,950	/dist	05:51 f19a0de CI-..
risk-analytics	Python	semgrep-std: 1.39.0	1.48.3	497	91,332	/tests	04:36 91a3ef0 CI-..
data-pipeline	Python	semgrep-std: 1.39.0	1.48.3	386	74,208	/generated	03:58 77db5e2 CI-..
wealth-net	C#	semgrep-std: 1.39.0	1.48.3	1,327	301,144	/obj, /bin	14:05 6b1296b CI-..
platform-foundation	Bash/Python	semgrep-std: 1.39.0	1.48.3	209	38,115	/vendor	02:49 0a9c2e1 CI-..
api-gateway	Node.js	semgrep-std: 1.39.0	1.48.3	431	80,774	/scripts	04:22 9f77a25 CI-..
shared-dto	Python	semgrep-std: 1.39.0	1.48.3	145	21,906	--	01:57 e2f5a13 CI-..
qa-tooling	Java/TS	semgrep-std: 1.39.0	1.48.3	318	60,288	/samples	03:24 12a5b47 CI-..
digital-ui	TS/React	semgrep-std: 1.39.0	1.48.3	903	168,012	/dist	06:17 a52cf11 CI-8..
analytics-shared	Python	semgrep-std: 1.39.0	1.48.3	238	43,501	/tests	02:42 4b3e1f9 CI-..

DAST session summary -- Sprint 42 (informational)

Session ID	Environment	Target scope	Auth context	Start	End	Requests	Avg latency (ms) ..
DAST-42-201	UAT	api-gateway, paym..	Synthetic acct: UA..	2026-07-17T02:00Z	2026-07-17T02:28Z	4,128	114 3,821 129 178..
DAST-42-202	UAT	onboarding-svc	Synthetic acct: UA..	2026-07-17T03:10Z	2026-07-17T03:39Z	3,409	121 3,114 97 198 ..
DAST-42-203	UAT	digital-ui (public pa..	Anonymous	2026-07-17T04:05Z	2026-07-17T04:27Z	2,286	96 1,942 214 130 ..
DAST-42-204	UAT	wealth-net	Synthetic acct: UA..	2026-07-17T05:15Z	2026-07-17T05:49Z	3,012	132 2,731 103 178..
DAST-42-205	UAT	data-pipeline API	Service token (non..	2026-07-17T06:20Z	2026-07-17T06:46Z	1,744	108 1,564 87 93 0 ..
DAST-42-206	UAT	risk-analytics API	Synthetic acct: UA..	2026-07-17T07:15Z	2026-07-17T07:40Z	1,982	119 1,778 82 122 ..
DAST-42-207	UAT	shared-dto (schem..	Anonymous	2026-07-17T08:05Z	2026-07-17T08:19Z	936	88 823 59 54 0 No..
DAST-42-208	UAT	mobile-ui (edge en..	Anonymous	2026-07-17T08:45Z	2026-07-17T09:06Z	1,521	101 1,312 106 103..
DAST-42-209	UAT	onboarding-svc (p..	Synthetic acct: UA..	2026-07-17T09:30Z	2026-07-17T09:57Z	2,744	127 2,469 103 172..

Cross-team review and reconciliation -- Sprint 42

Meeting date	Session	Participants	Topics	Actions logged	Doc ref	Next review
2026-07-18	SAST/DAST sync	AppSec Eng, Pay..	Rule tuning RT-42 ..	- Document final R..	MC-Sec-Std-2026-..	2026-08-01
2026-07-19	Platform QA touch..	QA Eng, Platform ..	Test path exclusio..	- Keep quarterly sn..	QA-Ops-Note-556	2026-08-02
2026-07-19	Service leads forum	Onboarding, Wealt..	Style rule adoption..	- Align formatter ve..	Dev-Guide-Appen..	2026-08-05

Scan performance indicators -- Sprint 42

Metric	Value	Prior sprint	Delta	Notes
Average SAST duration..	06:25	06:41	-00:16	Minor improvement due ..
Median files scanned p..	424	438	-14	Stable; minor repo restr..
Ruleset version adoption	100%	92%	+8%	All pipelines now on se..
DAST sessions complet..	9	9	0	On schedule
DAST anomaly rate	0.00%	0.00%	0.00%	No anomalies recorded

Structured logging com..	98.7%	96.9%	+1.8%	Continued adherence a..

All items above reflect routine operational maintenance and quality improvements. No escalation thresholds were reached, and no exceptions to policy were requested or recorded during this sprint window.

SAST/DAST Security Scan Report -- Sprint 42

Meridian Capital

Page 17 -- SAST Operational Metrics and Benign Review

The following operational snapshot summarizes Semgrep SAST coverage and informational outcomes for Sprint 42 across prioritized repositories. All entries reflect routine, non-security-impacting signals handled through the standard triage workflow. No security vulnerabilities were recorded, and all informational items were addressed as benign, design-intent, or test-only artifacts following established criteria. Timings, identifiers, and ownership reflect CI pipeline events from the current sprint window.

SAST Coverage and Informational Findings Summary -- Sprint 42

Product Area	Repository	Scan ID	Rules Enabled	Rules Quieted (Te..	Informational Sig..	Benign Confirmed	Files Scanned Du..
Retail Banking Mo..	mobile-app-ios	SAST-2026-07-21-..	624	38 / 22	71	71	2,184 06:54 2026-..
Retail Banking Mo..	mobile-app-android	SAST-2026-07-21-..	617	35 / 24	64	64	2,912 07:28 2026-..
Corporate Treasury	treasury-service	SAST-2026-07-21-..	682	42 / 31	59	59	1,756 05:17 2026-..
Capital Markets	algo-engine	SAST-2026-07-21-..	701	47 / 28	66	66	3,108 08:02 2026-..
Shared Platforms	api-gateway	SAST-2026-07-21-..	735	53 / 37	88	88	4,231 09:44 2026-..
Risk Analytics	credit-score	SAST-2026-07-21-..	689	40 / 29	52	52	1,529 04:59 2026-..
Data Platform	etl-pipeline	SAST-2026-07-21-..	612	31 / 33	73	73	5,487 10:13 2026-..
Finance IT	ledger-service	SAST-2026-07-21-..	668	36 / 26	41	41	1,108 03:48 2026-..
Identity & Access	idp-service	SAST-2026-07-21-..	744	55 / 35	77	77	3,764 08:35 2026-..
Client Portals	client-portal-web	SAST-2026-07-21-..	726	49 / 38	82	82	6,302 11:22 2026-..
Internal Tools	oncall-portal	SAST-2026-07-21-..	591	28 / 25	36	36	1,002 03:12 2026-..

Benign Findings Review Log -- Sprint 42

Ticket	Rule ID	File (Path)	Line	Severity	Status	Owner Team	Analyst Created (..
SEC-SAST-84211	generic.print-used	mobile-app-ios/Tes..	118	Info	Closed -- Benign	Mobile Engineering	G. Patel 2026-07-1..
SEC-SAST-84232	javascript.console-l..	client-portal-web/sr..	42	Info	Closed -- Benign	Client Portals	R. Nguyen 2026-0..
SEC-SAST-84277	comment.contains-..	api-gateway/intern..	7	Info	Acknowledged	Shared Platforms	K. Ahmed 2026-07..
SEC-SAST-84305	style.naming-conv..	treasury-service/sr..	63	Info	Closed -- Benign	Treasury Services	P. Romero 2026-0..
SEC-SAST-84341	test.only-mock-usa..	credit-score/tests/t..	29	Info	Closed -- Benign	Risk Analytics	H. McAllister 2026-..
SEC-SAST-84366	license.header.mis..	etl-pipeline/generat..	1	Info	Closed -- Benign	Data Platform	Z. Chen 2026-07-1..
SEC-SAST-84388	formatting.trailing-..	oncall-portal/app/te..	76	Info	Closed -- Benign	Developer Producti..	D. Simmons 2026-..
SEC-SAST-84402	proto.generated.no..	api-gateway/build/..	3	Info	Closed -- Benign	Shared Platforms	A. Kline 2026-07-1..
SEC-SAST-84427	docs.example-plac..	ledger-service/doc..	1	Info	Closed -- Benign	Finance IT	M. Ortega 2026-07..
SEC-SAST-84461	dead-code.unrefer..	idp-service/pkg/int..	12	Info	Closed -- Benign	Identity & Access	S. Tan 2026-07-19..
SEC-SAST-84483	style.line-length	algo-engine/src/sig..	201	Info	Closed -- Benign	Capital Markets	E. Dubois 2026-07..
SEC-SAST-84512	serialization.exam..	mobile-app-androi..	1	Info	Closed -- Benign	Mobile Engineering	L. Hoffman 2026-0..

Page 18 -- DAST Benign Signals and SAST Rule Tuning (Non-Security)

This section captures DAST signal validation outcomes that matched expected behaviors and non-security-impacting SAST rule tuning requests queued or completed during Sprint 42. All DAST observations reflect normal service responses under test harness conditions, and all rule-tuning items concern noise reduction, documentation clarity, or scoping to generated/test code. No policy exceptions were recorded.

DAST Signal Validation -- Expected/Benign Responses

Test Case	Service	Endpoint	Method	Expected Status	Observed Status	Resp Time (ms)	Variance (%) Hea..
DAST-EX-11021	client-portal-web	/healthz	GET	200	200	42	3.1 Standard head..
DAST-EX-11022	api-gateway	/v1/status	GET	200	200	57	5.4 Standard head..
DAST-EX-11023	treasury-service	/actuator/info	GET	200	200	83	4.7 Standard head..
DAST-EX-11024	idp-service	/oauth/.well-known..	GET	200	200	96	2.9 Standard head..
DAST-EX-11025	ledger-service	/metrics	GET	200	200	74	4.0 Standard head..
DAST-EX-11026	algo-engine	/version	GET	200	200	39	3.8 Standard head..
DAST-EX-11027	mobile-app-ios bac..	/api/ping	GET	200	200	51	2.5 Standard head..
DAST-EX-11028	mobile-app-androi..	/bff/config	GET	200	200	63	5.2 Standard head..
DAST-EX-11029	etl-pipeline svc	/status	GET	200	200	112	6.0 Standard head..
DAST-EX-11030	oncall-portal	/auth/health	GET	200	200	47	3.3 Standard head..
DAST-EX-11031	api-gateway	/v1/redirect	GET	302	302	35	2.7 Redirect policy ..
DAST-EX-11032	client-portal-web	/static/logo.png	GET	200	200	28	3.0 Static asset he..

Rule Tuning and Documentation Backlog (Non-Security Impact)

Request ID	Rule Key	Title	Requested Change	Rationale	Impacted Repos	Priority	Requested By Tar..
RT-2026-042-01	javascript.console-l..	Console logs behin..	Scope to non-prod ..	Reduce noise in fr..	client-portal-web	Medium	R. Nguyen 43 Appr..
RT-2026-042-02	license.header.mis..	License header in ..	Auto-suppress in /..	Codegen emits file..	api-gateway, etl-pi..	High	A. Kline 43 Implem..
RT-2026-042-03	comment.contains-..	TODO/NOTE com..	Downgrade to Info ..	Planning markers i..	treasury-service, id..	Low	K. Ahmed 44 Prop..
RT-2026-042-04	proto.generated.no..	Generated proto lint	Suppress in known..	Align with code ge..	etl-pipeline	High	Z. Chen 43 Approv..
RT-2026-042-05	style.naming-conv..	Legacy naming ex..	Add per-package a..	Legacy classes unt..	treasury-service	Medium	P. Romero 44 Und..
RT-2026-042-06	generic.print-used	Print usage in tests	Limit to test directo..	Diagnostics in unit ..	mobile-app-ios, mo..	High	G. Patel 43 Imple..
RT-2026-042-07	dead-code.unrefer..	Unreferenced help..	Exclude /testutils f..	Maintained for har..	idp-service, algo-e..	Medium	S. Tan 44 Propose..
RT-2026-042-08	formatting.trailing-..	Trailing whitespace	Route to formatter ..	Pre-commit auto-fi..	oncall-portal, client..	Low	D. Simmons 44 Ap..
RT-2026-042-09	docs.example-plac..	Example/placehold..	Document safe loc..	Distinguish docs/e..	ledger-service, api-..	Medium	M. Ortega 44 Unde..
RT-2026-042-10	serialization.exam..	Snapshot artifact d..	Tag as non-runtim..	Reduce noise from..	mobile-app-android	Medium	L. Hoffman 43 Impl..
RT-2026-042-11	style.line-length	Line length guidan..	Increase threshold ..	Long inline tables ..	algo-engine	Low	E. Dubois 45 Prop..
RT-2026-042-12	tests.only-mock-us..	Mocking framewor..	Affirm allowlist	Common test patte..	credit-score, ledge..	High	H. McAllister 43 Ap..

SAST/DAST Security Scan Report -- Sprint 42

Meridian Capital

Page 19 -- Rule Tuning Outcomes and Execution Metrics

During Sprint 42 the Security Engineering Ops team completed a scheduled review of semgrep rule coverage across core application repositories. The activity focused on consolidating overlapping informational checks, tagging rules for consistent reporting, and ensuring noise from legacy patterns does not obscure relevant signal. No security-impacting issues were identified or reported; all items below are benign and operational in nature. Decisions reflect harmonization with coding standards, third-party library deprecations, and environment-specific exclusions (e.g., generated code, vendor folders). Each entry documents the repository, rule identifier, decision outcome, and associated governance metadata for audit continuity.

Semgrep Rule Tuning Decisions -- Sprint 42

Repo	Component	Rule ID	Category	Severity	Decision	Rationale	Ticket Ref Review..
payments-service	api	generic.logging.pri..	Logging	Info	Keep	Standardize printf l..	SEMG-4211 L. Ah..
payments-service	db	java.correctness.o..	Correctness	Info	Keep	Advisory for Option..	SEMG-4212 K. Bo..
payments-service	worker	generic.todo.comm..	Hygiene	Info	Retain w/ tag hygie..	Track TODO densi..	SEMG-4213 V. Ch..
risk-engine	core	py.style.no-wildcar..	Style	Info	Keep	Enforces readabilit..	SEMG-4214 M. Di..
risk-engine	adapters	py.logging.fstring-f..	Logging	Info	Merge	Merge into logging..	SEMG-4215 R. Ev..
risk-engine	adapters	py.logging.percent-..	Logging	Info	Merge	Duplicate of fstring..	SEMG-4216 R. Ev..
web-portal	ui	ts.react.display-na..	Best Practice	Info	Keep	Aids component di..	SEMG-4217 H. Flo..
web-portal	ui	ts.no-console-log	Hygiene	Info	Scope to dev	Restrict to develop..	SEMG-4218 H. Flo..
mobile-ios	app	swift.todo.comment	Hygiene	Info	Keep	Track TODO/NOT..	SEMG-4219 I. Gup..
mobile-ios	app	swift.deprecated.a..	Deprecation	Info	Keep	Monitor SDK depre..	SEMG-4220 I. Gup..
mobile-android	app	kotlin.nullness.elvi..	Style	Info	Keep	Non-blocking style ..	SEMG-4221 J. Hal..
mobile-android	app	kotlin.deprecated.a..	Deprecation	Info	Keep	Track library annot..	SEMG-4222 J. Hal..
data-pipeline	ingest	py.pandas.copy-ch..	Correctness	Info	Keep	Advisory on chaine..	SEMG-4223 S. Ito ..
data-pipeline	transform	py.datetime.tz-awa..	Best Practice	Info	Keep	Encourages timez..	SEMG-4224 S. Ito ..
aml-monitor	rules	yaml.schema.missi..	Documentation	Info	Keep	Schema doc compl..	SEMG-4225 T. Jo..
aml-monitor	rules	yaml.key.ordering	Style	Info	Defer	Non-essential; revi..	SEMG-4226 T. Jo..
infra-terraform	modules	tf.resource.tagging..	Compliance	Info	Keep	Aligns with tagging..	SEMG-4227 U. Ki..
infra-terraform	modules	tf.variable.descripti..	Documentation	Info	Keep	Documentation co..	SEMG-4228 U. Ki..
quant-research	notebooks	py.notebook.nbout..	Hygiene	Info	Keep	Ensures clean not..	SEMG-4229 W. Le..
quant-research	libs	py.type.hint.require..	Best Practice	Info	Keep	Public functions ty..	SEMG-4230 W. Le..
ops-tooling	cli	go.log.printf-usage	Logging	Info	Merge	Consolidate with lo..	SEMG-4231 P. Ma..
ops-tooling	cli	go.error.wrap	Best Practice	Info	Keep	Encourages error ..	SEMG-4232 P. Ma..
treasury-ledger	service	java.streams.prefe..	Style	Info	Keep	Style-only; benign	SEMG-4233 Q. Ng..
treasury-ledger	service	java.logging.param..	Logging	Info	Keep	Enforce parameteri..	SEMG-4234 Q. Ng..
web-portal	api	js.promise.no-floati..	Correctness	Info	Keep	Advisory on unhan..	SEMG-4235 R. Ort..
web-portal	api	js.deprecation.fetc..	Deprecation	Info	Keep	Tracks API deprec..	SEMG-4236 R. Ort..
core-shared	libs	license.header.pre..	Compliance	Info	Keep	License header enf..	SEMG-4237 S. Pat..
core-shared	libs	file.no-tabs	Style	Info	Keep	Consistent whitesp..	SEMG-4238 S. Pat..
retail-banking	backend	kotlin.logging.place..	Logging	Info	Keep	Align message tem..	SEMG-4239 T. Qui..
retail-banking	backend	kotlin.data.class.eq..	Correctness	Info	Keep	Advisory; non-bloc..	SEMG-4240 T. Qui..

Scan Execution Metrics -- Sprint 42 Runs

Build ID	Job	Engine Ver	Start (UTC)	End (UTC)	Duration	Ruleset	Files Matches (Inf..
CI-98621	payments-service_..	1.61.0	2026-07-19T12:00:..	2026-07-19T12:06:..	6m36s	mc-enterprise-java	1,482 214 build-no..
CI-98622	risk-engine_sast	1.61.0	2026-07-19T12:10:..	2026-07-19T12:17:..	7m16s	mc-enterprise-pyth..	2,035 307 build-no..
CI-98623	web-portal_sast	1.61.0	2026-07-19T12:21:..	2026-07-19T12:31:..	9m31s	mc-enterprise-js-ts	3,224 451 build-no..
CI-98624	mobile-ios_sast	1.61.0	2026-07-19T12:35:..	2026-07-19T12:42:..	7m05s	mc-enterprise-swift	1,118 146 mac-run..
CI-98625	mobile-android_sast	1.61.0	2026-07-19T12:46:..	2026-07-19T12:55:..	9m11s	mc-enterprise-kotlin	1,396 198 android-..

CI-98626	data-pipeline_sast	1.61.0	2026-07-19T13:01:..	2026-07-19T13:08:..	7m24s	mc-enterprise-pyth..	1,742 163 build-no..
CI-98627	aml-monitor_sast	1.61.0	2026-07-19T13:11:..	2026-07-19T13:16:..	4m19s	mc-enterprise-yaml	389 57 build-node-..
CI-98628	infra-terraform_sast	1.61.0	2026-07-19T13:19:..	2026-07-19T13:23:..	4m07s	mc-enterprise-terra..	512 72 build-node-..
CI-98629	quant-research_sa..	1.61.0	2026-07-19T13:26:..	2026-07-19T13:31:..	5m48s	mc-enterprise-pyth..	864 101 build-nod..
CI-98630	ops-tooling_sast	1.61.0	2026-07-19T13:35:..	2026-07-19T13:39:..	4m47s	mc-enterprise-go	603 84 build-node-..
CI-98631	treasury-ledger_sa..	1.61.0	2026-07-19T13:43:..	2026-07-19T13:50:..	7m33s	mc-enterprise-java	1,109 132 build-no..
CI-98632	retail-banking_sast	1.61.0	2026-07-19T13:55:..	2026-07-19T14:03:..	7m31s	mc-enterprise-kotlin	1,287 176 build-no..
CI-98633	core-shared_sast	1.61.0	2026-07-19T14:06:..	2026-07-19T14:11:..	4m55s	mc-enterprise-mix..	721 95 build-node-..
CI-98634	web-portal_sast-ni..	1.61.0	2026-07-20T00:01:..	2026-07-20T00:10:..	9m36s	mc-enterprise-js-ts	3,241 449 build-no..
CI-98635	payments-service_..	1.61.0	2026-07-20T00:12:..	2026-07-20T00:18:..	6m21s	mc-enterprise-java	1,497 218 build-no..

Observations: The merge of duplicate logging-format rules reduced redundant informational matches in risk-engine and ops-tooling by 11-14% without affecting reporting fidelity. All runs completed within expected SLAs. No remediation tickets were generated; all entries tracked above pertain to non-actionable best practice and hygiene signals.

SAST/DAST Security Scan Report -- Sprint 42

Meridian Capital

Page 20 -- Informational Findings Review Log

This page records the triage of informational-only semgrep matches during Sprint 42. The objective was to maintain a low-noise baseline by closing routine hygiene, style, and documentation advisories as non-actionable where they align with established standards or occur in test, sample, or generated code. All items were reviewed by the owning teams and Security Engineering Ops, with final dispositions captured for traceability. No security vulnerabilities were identified in this set; all findings are benign and procedural.

Informational Findings Triaged -- Closed as Non-Actionable

Repo	Path	Pattern	Rule ID	Occurrences	Disposition	Notes	Ticket Triager Clo..
payments-service	api/src/main/java/....	Logging placehold..	java.logging.param..	4	Closed -- Compliant	Matches align with ..	SEMG-4241 L. Ah..
payments-service	worker/src/.../Reco..	TODO comment pr..	generic.todo.comm..	3	Closed -- Tracked	Linked to backlog ..	SEMG-4242 V. Ch..
payments-service	db/src/.../Schema..	License header mi..	license.header.pre..	1	Closed -- Generated	Flyway-generated f..	SEMG-4243 K. Bo..
risk-engine	adapters/orderboo..	Logging format ch..	py.logging.fstring-f..	6	Closed -- Compliant	Canonical format i..	SEMG-4244 R. Ev..
risk-engine	core/position_calc...	Optional access ad..	py.correctness.opti..	2	Closed -- Advisory	Readability note o..	SEMG-4245 M. Di..
risk-engine	tests/test_router.py	Wildcard import	py.style.no-wildcar..	1	Closed -- Test Sco..	Test code excluded	SEMG-4246 M. Di..
web-portal	ui/src/components/..	React display name	ts.react.display-na..	5	Closed -- Compliant	Convention docum..	SEMG-4247 H. Flo..
web-portal	ui/src/utils/log.ts	Console usage	ts.no-console-log	2	Closed -- Dev Only	Dev helper gated b..	SEMG-4248 R. Ort..
web-portal	api/src/fetcher.ts	Promise handling	js.promise.no-floati..	1	Closed -- Compliant	Promise handled d..	SEMG-4249 R. Ort..
mobile-ios	App/Features/Profi..	Deprecated API call	swift.deprecated.a..	2	Closed -- Planned ..	Covered by SDK u..	SEMG-4250 I. Gup..
mobile-ios	App/Support/Notes..	TODO note	swift.todo.comment	1	Closed -- Tracked	Linked to IOS-590	SEMG-4251 I. Gup..
mobile-android	app/src/main/.../Ho..	Nullness style pref..	kotlin.nullness.elvi..	3	Closed -- Style Only	Non-blocking reco..	SEMG-4252 J. Hal..
mobile-android	app/src/test/.../Rep..	Deprecated annota..	kotlin.deprecated.a..	1	Closed -- Test Sco..	Unit test only	SEMG-4253 J. Hal..
data-pipeline	ingest/loader.py	Pandas chained co..	py.pandas.copy-ch..	2	Closed -- Advisory	Readability; no iss..	SEMG-4254 S. Ito ..
data-pipeline	transform/time_op..	TZ-aware datetime	py.datetime.tz-awa..	4	Closed -- Compliant	TZ used via utility ..	SEMG-4255 S. Ito ..
aml-monitor	rules/kyc.yml	Schema description	yaml.schema.missi..	1	Closed -- Doc Bac..	KYC-1219 to fill de..	SEMG-4256 T. Jo..
aml-monitor	rules/sanctions.yml	Key ordering	yaml.key.ordering	8	Closed -- Low Prio..	Style-only; parked	SEMG-4257 T. Jo..
infra-terraform	modules/vpc/outpu..	Tagging required	tf.resource.tagging..	1	Closed -- Compliant	Tags present via m..	SEMG-4258 U. Ki..
infra-terraform	modules/iam/varia..	Variable description	tf.variable.descripti..	2	Closed -- Tracked	TF-882 add descri..	SEMG-4259 U. Ki..
quant-research	notebooks/alpha1.i..	Outputs present	py.notebook.nbout..	1	Closed -- Generated	CI clears on commit	SEMG-4260 W. Le..
quant-research	libs/signals.py	Public type hints	py.type.hint.require..	3	Closed -- Advisory	Roadmap to expan..	SEMG-4261 W. Le..
ops-tooling	cli/main.go	Error wrapping	go.error.wrap	2	Closed -- Compliant	Context added via ..	SEMG-4262 P. Ma..
ops-tooling	cli/logging.go	Logging printf	go.log.printf-usage	1	Closed -- Merged ..	Covered by umbrel..	SEMG-4263 P. Ma..
treasury-ledger	service/src/.../Jour..	Streams collector s..	java.streams.prefe..	5	Closed -- Style Only	Readability sugges..	SEMG-4264 Q. Ng..
retail-banking	backend/src/.../Cu..	Logging placeholder	kotlin.logging.place..	2	Closed -- Compliant	Uses parameterize..	SEMG-4265 T. Qui..
core-shared	libs/src/.../Precondi..	License header	license.header.pre..	1	Closed -- Compliant	Header present via..	SEMG-4266 S. Pat..

nosemgrep Annotation Review -- Compliance Summary

Repo	File	Line	Tag	Justification Sum..	Entered By	Entered At (UTC)	Reviewed By Rev..
payments-service	worker/.../SampleD..	42	nosemgrep	Generated test fixt..	V. Chen	2026-07-18T11:12:..	L. Ahmed 2026-07..
risk-engine	tests/.../mock_feed..	77	nosemgrep	Intentional wildcar..	M. Diaz	2026-07-18T12:45:..	R. Evans 2026-07-..
web-portal	ui/src/devtools/log..	19	nosemgrep	Dev console utility	H. Flores	2026-07-18T14:12:..	R. Ortiz 2026-07-2..
mobile-ios	App/Preview/Previ..	33	nosemgrep	UI preview-only co..	I. Gupta	2026-07-18T15:10:..	I. Gupta 2026-07-2..
mobile-android	app/src/debug/.../D..	28	nosemgrep	Debug build type o..	J. Hall	2026-07-18T16:10:..	J. Hall 2026-07-20..
data-pipeline	notebooks/utils.py	12	nosemgrep	Notebook export fo..	S. Ito	2026-07-18T17:05:..	S. Ito 2026-07-20T..
aml-monitor	rules/_templates.y..	5	nosemgrep	Template placehol..	T. Jones	2026-07-18T17:58:..	T. Jones 2026-07-..
infra-terraform	modules/_gen/outp..	3	nosemgrep	Auto-generated ou..	U. Kim	2026-07-18T19:08:..	U. Kim 2026-07-20..
quant-research	notebooks/exampl..	1	nosemgrep	Educational examp..	W. Lee	2026-07-18T20:02:..	W. Lee 2026-07-2..
ops-tooling	cli/internal/testdata..	2	nosemgrep	Test data literal val..	P. Malik	2026-07-18T21:01:..	P. Malik 2026-07-2..

treasury-ledger	service/src/test/.../..	16	nosemgrep	Test scaffolding on..	Q. Nguyen	2026-07-18T21:59:..	Q. Nguyen 2026-0..
retail-banking	backend/src/demo/..	9	nosemgrep	Demo code in doc..	T. Quinn	2026-07-18T22:10:..	T. Quinn 2026-07-..

Summary: All nosemgrep annotations reviewed this sprint were confined to test, generated, or developer-only contexts and met documentation requirements. No production path suppressions were identified. The central registry in SEMG-4201 was updated to reflect these approvals for audit parity.

Page 21 -- Semgrep SAST Operational Ledger (Meridian Capital, SAST/DAST Security Scan Report -- Sprint 42)

The following tables document Semgrep SAST execution details for Sprint 42, including rule catalog coverage, CI job lineage, and review acknowledgements. All results are informational and aligned to code quality, consistency, and observability standards; no exploitable conditions were observed or recorded this sprint.

Semgrep Rule Execution Catalog -- Sprint 42

Rule ID	Friendly Name	Category	Severity	Triggered Count	New vs Baseline	Execution Status	Rationale Owning..
MCAP-SG-00112	Logging Format C..	Logging	Info	14	1 new / 13 baseline	Executed	Maintain standardi..
MCAP-SG-00119	License Header Pr..	Compliance	Info	27	0 / 27	Executed	Ensure repo-level l..
MCAP-SG-00127	Deprecated API Im..	Maintainability	Low (Policy)	8	0 / 8	Executed	Flag soft-deprecat..
MCAP-SG-00133	Test Only Print Us..	Test Hygiene	Info	19	3 / 16	Executed	Encourage structur..
MCAP-SG-00151	JSON Property Na..	Style	Info	11	0 / 11	Executed	Enforce snake_cas..
MCAP-SG-00162	Serializable Annot..	Serialization	Info	6	0 / 6	Executed	Consistency for DT..
MCAP-SG-00179	HTTP Client Timeo..	Reliability	Low (Policy)	22	1 / 21	Executed	Ensure bounded n..
MCAP-SG-00185	Internationalization..	I18N	Info	9	0 / 9	Executed	Consistent i18n ke..
MCAP-SG-00194	Kotlin Coroutine S..	Concurrency	Info	7	0 / 7	Executed	Readable and trac..
MCAP-SG-00202	Swift Lint Bridge (I..	iOS Quality	Info	18	2 / 16	Executed	Surface lint topics i..
MCAP-SG-00211	Python Typing Hint..	Maintainability	Info	13	0 / 13	Executed	Type clarity for criti..
MCAP-SG-00224	SQL Mapper Nami..	Style	Info	5	0 / 5	Executed	Consistent mapper..
MCAP-SG-00237	gRPC Stub Init Pat..	Integration	Info	10	1 / 9	Executed	Standardized client..
MCAP-SG-00245	React PropTypes ..	UI Quality	Info	12	0 / 12	Executed	Bridge until full TS ..
MCAP-SG-00258	Telemetry Tag For..	Observability	Low (Policy)	21	0 / 21	Executed	Normalized span a..
MCAP-SG-00263	YAML Schema Ali..	DevOps	Info	16	0 / 16	Executed	Verify CI key prese..
MCAP-SG-00274	Proto Field Numbe..	API	Info	4	0 / 4	Executed	Catalog gaps for d..
MCAP-SG-00289	Domain Event Na..	Architecture	Info	15	1 / 14	Executed	Ubiquitous langua..
MCAP-SG-00293	Spring Bean Qualif..	Java	Info	6	0 / 6	Executed	Readable DI disam..
MCAP-SG-00301	Git Commit Tag in ..	Release Eng	Info	20	0 / 20	Executed	Traceability in artif..
MCAP-SG-00309	Kafka Topic Namin..	Messaging	Info	9	0 / 9	Executed	Consistency for pla..
MCAP-SG-00312	Avro Schema Doc ..	Data	Info	7	0 / 7	Executed	Improve lineage an..
MCAP-SG-00320	CI Annotation Pres..	Dev Workflow	Info	31	2 / 29	Executed	Ensure PR surface..

Scan Job Ledger -- SAST Pipelines (Sprint 42)

Job ID	Repository	Branch	Commit (short)	Start Time (UTC)	End Time (UTC)	Duration	Runner Result Sc..
SAST-42-1101	mcap-retail-api	main	a9c7d12	2026-07-15T04:02:..	2026-07-15T04:05:..	3m42s	runner-east-03 Pa..
SAST-42-1102	mcap-wealth-portal	release/6.4	d1f2bb8	2026-07-15T04:18:..	2026-07-15T04:22:..	3m28s	runner-east-02 Pa..
SAST-42-1103	treasury-ledger-svc	main	4b33a54	2026-07-15T05:01:..	2026-07-15T05:04:..	2m58s	runner-west-01 Pa..
SAST-42-1104	authn-gateway	develop	5a90e1d	2026-07-15T05:22:..	2026-07-15T05:26:..	3m57s	runner-east-01 Pa..
SAST-42-1105	mobile-ios-app	main	f7e1c2a	2026-07-15T06:10:..	2026-07-15T06:14:..	4m17s	runner-mac-02 Pa..
SAST-42-1106	mobile-android-app	release/12.1	0cce4d9	2026-07-15T06:28:..	2026-07-15T06:31:..	3m29s	runner-android-01 ..
SAST-42-1107	data-pipeline-ingest	main	2f1a0a7	2026-07-15T07:02:..	2026-07-15T07:05:..	2m39s	runner-west-02 Pa..
SAST-42-1108	kafka-streams-con..	develop	6b1294c	2026-07-15T07:21:..	2026-07-15T07:24:..	2m57s	runner-west-02 Pa..
SAST-42-1109	ux-design-system	main	932acb1	2026-07-15T07:55:..	2026-07-15T07:58:..	2m48s	runner-east-03 Pa..
SAST-42-1110	risk-scorer	feature/exp-a	e0aa2f5	2026-07-15T08:18:..	2026-07-15T08:21:..	3m52s	runner-west-01 Pa..
SAST-42-1111	aml-monitoring	main	7cde188	2026-07-15T08:35:..	2026-07-15T08:38:..	3m41s	runner-west-03 Pa..
SAST-42-1112	ops-automation	develop	3f72c9d	2026-07-15T09:02:..	2026-07-15T09:05:..	2m33s	runner-east-02 Pa..
SAST-42-1113	enterprise-integrati..	main	a1b0d44	2026-07-15T09:21:..	2026-07-15T09:25:..	4m05s	runner-west-01 Pa..
SAST-42-1114	payments-ui-web	hotfix/px-918	5f5e7aa	2026-07-15T09:41:..	2026-07-15T09:44:..	2m51s	runner-east-03 Pa..
SAST-42-1115	core-shared-libs	main	11de3a2	2026-07-15T10:05:..	2026-07-15T10:07:..	2m33s	runner-west-02 Pa..

Team Review Acknowledgements -- Sprint 42

Ticket Ref	Team	Reviewer	Review Time (UT..	Outcome	Notes	Linked Job ID
MCAP-SAST-42-0..	Digital Banking Pla..	A. Mehta	2026-07-15T11:02..	Acknowledged	Informational items..	SAST-42-1101
MCAP-SAST-42-0..	Wealth Engineering	J. Ortega	2026-07-15T11:18..	Acknowledged	UI lint surfaced cor..	SAST-42-1102

MCAP-SAST-42-0..	Treasury & Liquidity	P. Chen	2026-07-15T11:42..	Acknowledged	Logging format up..	SAST-42-1103
MCAP-SAST-42-0..	Identity Services	M. Fischer	2026-07-15T12:05..	Acknowledged	Bean qualifiers co..	SAST-42-1104
MCAP-SAST-42-0..	Retail Mobile	K. Yamamoto	2026-07-15T12:22..	Acknowledged	iOS/Android rules ..	SAST-42-1105
MCAP-SAST-42-0..	Data Platforms	R. Gupta	2026-07-15T12:44..	Acknowledged	Avro schema doc ..	SAST-42-1107
MCAP-SAST-42-0..	Enterprise Integrati..	L. Pereira	2026-07-15T13:06..	Acknowledged	gRPC init pattern i..	SAST-42-1113
MCAP-SAST-42-0..	Payments & Treas..	H. Singh	2026-07-15T13:28..	Acknowledged	HTTP timeout pres..	SAST-42-1114
MCAP-SAST-42-0..	Cloud Foundations	D. Morales	2026-07-15T13:49..	Acknowledged	CI annotations surf..	SAST-42-1115
MCAP-SAST-42-0..	Cyber Risk Engine..	E. Novak	2026-07-15T14:12..	Acknowledged	Rulepack parity ve..	Multiple

Page 22 -- DAST Coverage and Platform Metrics (Meridian Capital, SAST/DAST Security Scan Report -- Sprint 42)

This page summarizes DAST passive scan coverage alongside quality gates and service-level indicators for Sprint 42. All scans completed within defined windows; observed signals were informational, and no action-required items were raised.

DAST Endpoint Coverage and Passive Signals -- Sprint 42

Service	Environment	Auth Context	Endpoints Crawled	Passive Signals (I..	Avg Latency (ms)	Max Depth	Scan Window (UT..
retail-api	stage	OAuth2	164	12	143	4	2026-07-14T02:10..
retail-api	prod	OAuth2	171	11	138	4	2026-07-15T03:05..
wealth-portal	stage	SSO	119	8	211	3	2026-07-14T04:00..
wealth-portal	prod	SSO	123	9	205	3	2026-07-15T05:40..
treasury-ledger	stage	MTLS	58	6	97	2	2026-07-14T06:10..
treasury-ledger	prod	MTLS	61	5	101	2	2026-07-15T06:30..
authn-gateway	stage	N/A	44	7	82	2	2026-07-14T07:05..
authn-gateway	prod	N/A	47	6	78	2	2026-07-15T07:15..
payments-ui	stage	SSO	132	10	236	3	2026-07-14T08:12..
payments-ui	prod	SSO	137	9	229	3	2026-07-15T08:21..
mobile-api	stage	OAuth2	95	7	121	3	2026-07-14T09:11..
mobile-api	prod	OAuth2	98	7	125	3	2026-07-15T09:10..
data-catalog	stage	SSO	41	4	264	2	2026-07-14T10:01..
data-catalog	prod	SSO	43	4	258	2	2026-07-15T10:00..
ops-portal	stage	SSO	52	5	187	2	2026-07-14T10:40..
ops-portal	prod	SSO	54	5	181	2	2026-07-15T10:42..
aml-monitoring-ui	stage	SSO	73	6	233	3	2026-07-14T11:12..
aml-monitoring-ui	prod	SSO	75	6	227	3	2026-07-15T11:16..
risk-scorer-api	stage	MTLS	39	3	109	2	2026-07-14T12:05..
risk-scorer-api	prod	MTLS	40	3	112	2	2026-07-15T12:08..

Informational Signal Adjudication Log -- Sprint 42 (DAST)

Ticket Ref	Service	Team	Logged (UTC)	Disposition	Reviewer	Notes	Evidence ID
DAST-OBS-42-02..	retail-api	Digital Banking Pla..	2026-07-15T03:36:..	Non-actionable	E. Novak	Header enumerati..	EVD-42-1002
DAST-OBS-42-02..	wealth-portal	Wealth Engineering	2026-07-15T06:09:..	Non-actionable	J. Ortega	Crawling depth ex..	EVD-42-1004
DAST-OBS-42-02..	treasury-ledger	Payments & Treas..	2026-07-15T06:50:..	Non-actionable	H. Singh	MTLS handshake t..	EVD-42-1006
DAST-OBS-42-02..	authn-gateway	Identity Services	2026-07-15T07:30:..	Non-actionable	M. Fischer	Redirects within po..	EVD-42-1008
DAST-OBS-42-02..	payments-ui	Payments & Treas..	2026-07-15T08:52:..	Non-actionable	P. Chen	Static assets cach..	EVD-42-1010
DAST-OBS-42-02..	mobile-api	Retail Mobile	2026-07-15T09:34:..	Non-actionable	K. Yamamoto	Version banner pre..	EVD-42-1012
DAST-OBS-42-02..	data-catalog	Data Platforms	2026-07-15T10:16:..	Non-actionable	R. Gupta	Graph introspectio..	EVD-42-1014
DAST-OBS-42-02..	ops-portal	Cloud Foundations	2026-07-15T11:00:..	Non-actionable	D. Morales	CSP report-only tel..	EVD-42-1016
DAST-OBS-42-02..	aml-monitoring-ui	Risk & Compliance..	2026-07-15T11:40:..	Non-actionable	L. Pereira	Analytics beacons ..	EVD-42-1018
DAST-OBS-42-02..	risk-scorer-api	Data Science Eng	2026-07-15T12:23:..	Non-actionable	A. Mehta	Healthcheck verbo..	EVD-42-1020
DAST-OBS-42-02..	enterprise-integrati..	Enterprise Integrati..	2026-07-15T12:44:..	Non-actionable	P. Russo	gRPC reflection off..	EVD-42-1021
DAST-OBS-42-02..	core-shared-libs (..	Core Platform	2026-07-15T13:10:..	Non-actionable	C. Alvarez	Test harness bann..	EVD-42-1022

Quality Gates & SLI Metrics -- Sprint 42 (SAST/DAST)

Metric	Target	Sprint 42 Actual	Variance	Owner	Notes	Timestamp (UTC)
Semgrep Rulepac..	<= 7 days	1 day	Within	Cyber Risk Eng	Pulled 2026.07 set	2026-07-15T07:55..
Average SAST Ru..	<= 5m00s	3m12s	Within	DevSecOps	Across 15 jobs	2026-07-15T10:30..
SAST Parser War..	0	0	Within	DevSecOps	No parse anomalies	2026-07-15T10:30..
SARIF Export Size..	<= 5 MB	3.6 MB	Within	DevSecOps	Compression enab..	2026-07-15T10:30..
DAST Window Ad..	100%	100%	Within	AppSec	All scans completed	2026-07-15T12:30..
Passive Signal Rat..	N/A	6.8	Informational	AppSec	No action required	2026-07-15T12:30..

Coverage: Repos ..	>= 95%	97%	Within	DevSecOps	31/32 active repos	2026-07-15T10:30..
Coverage: Service..	>= 90%	93%	Within	AppSec	14/15 tier-1/2 servi..	2026-07-15T12:30..
CI Queue Depth (p..	<= 4	2	Within	Cloud Foundations	Stable executors	2026-07-15T09:00..
Artifact Retention ..	100%	100%	Within	DevOps	S3 lifecycle verified	2026-07-15T13:00..
Rule Execution Err..	0	0	Within	Cyber Risk Eng	No timeouts	2026-07-15T07:55..
DAST Avg Latency..	<= +10%	+3%	Within	SRE	Normal range	2026-07-15T12:30..
Alert Routing to Te..	100%	100%	Within	AppSec	All tickets assigned	2026-07-15T13:15..
Review SLA (Info i..	<= 2 biz days	< 1 day	Within	All Teams	Early acknowledge..	2026-07-15T14:00..
Rule Coverage Sta..	>= 98%	99.2%	Within	Cyber Risk Eng	No rule gaps	2026-07-15T07:55..
Build Impact (p95 t..	<= +2m	+0m52s	Within	DevSecOps	Parallelized scans	2026-07-15T10:30..
Evidence Sample ..	100%	100%	Within	AppSec	Linked in tickets	2026-07-15T13:15..
Toolchain Uptime (..	>= 99.9%	100%	Within	SRE	No incidents	2026-07-15T14:10..

Appendix: Identifier Catalog -- Sprint 42

Application ID	Repository	Codeowners (Pri..	Team	ServiceNow CI	Jira Project	Contact
APP-DB-001	mcap-retail-api	@db-platform, @ri..	Digital Banking Pla..	SN-CI-10442	DBP	dbp-eng@meridia..
APP-WE-014	mcap-wealth-portal	@wealth-ui, @cor..	Wealth Engineering	SN-CI-10510	WEALTH	wealth-eng@merid..
APP-TL-022	treasury-ledger-svc	@treasury-core	Payments & Treas..	SN-CI-10587	TRSY	treasury-tech@me..
APP-ID-008	authn-gateway	@identity-sre	Identity Services	SN-CI-10311	IDP	idp-team@meridia..
APP-MB-019	mobile-ios-app	@retail-mobile	Retail Mobile	SN-CI-10634	MOB	mobile@meridianc..
APP-MB-020	mobile-android-app	@retail-mobile	Retail Mobile	SN-CI-10635	MOB	mobile@meridianc..
APP-DP-030	data-pipeline-ingest	@data-platform	Data Platforms	SN-CI-10228	DATA	data-platform@me..
APP-KF-033	kafka-streams-con..	@data-platform	Data Platforms	SN-CI-10602	DATA	data-platform@me..
APP-UX-040	ux-design-system	@design-systems	UX Engineering	SN-CI-10477	UX	ux@meridiancap.c..
APP-RS-047	risk-scorer	@risk-ml	Data Science Eng	SN-CI-10641	RISK	risk-ml@meridianc..
APP-AML-055	aml-monitoring	@risk-ops	Risk & Compliance..	SN-CI-10399	AML	aml-tech@meridia..
APP-OPS-061	ops-automation	@core-platform	Cloud Foundations	SN-CI-10411	OPS	ops-platform@mer..
APP-EI-071	enterprise-integrati..	@integration-core	Enterprise Integrati..	SN-CI-10658	INT	ei-core@meridianc..
APP-PY-081	core-shared-libs	@platform-java	Core Platform	SN-CI-10273	CPLAT	core-platform@me..

SAST/DAST Security Scan Report -- Sprint 42 -- Meridian Capital

Page 23 -- Semgrep SAST Benign Matches, Coverage, and Operations Summary

All Semgrep SAST activity for Sprint 42 was completed across the Client Portal, API Gateway, Treasury Ops, and Risk Analytics repositories. The findings during this sprint were limited to informational and best-practice rule hits. AppSec Engineering and Platform Security jointly reviewed all signals. No exploitable behaviors were identified, and no code paths met escalation criteria. The following tables document the benign matches, coverage metrics, and lifecycle operations applied during the sprint.

Semgrep Match Review Log -- Sprint 42 (Benign/Informational)

Ticket Ref	Rule ID	Rule Title	Severity	Repository/Path	Commit SHA	Filepath	Lines Match Cont..
MCAP-SEC-7421	generic.best-practi..	Assertions limited t..	Info	client-portal	8c2a9f1	tests/ui/test_nav.py	112-118 Unit-test a..
MCAP-SEC-7422	python.style.f-strin..	f-string style consis..	Info	api-gateway	5a7e4bd	services/ingest/me..	44-49 String interp..
MCAP-SEC-7423	java.best-practices..	Optional used for n..	Info	treasury-ops	cf91a2d	src/main/java/io/m..	201-210 Optional c..
MCAP-SEC-7424	js.node.logger-usa..	Structured logger p..	Info	client-portal	113ffb0	src/logging/index.ts	15-29 Structured fi..
MCAP-SEC-7425	yaml.cicd.no-plain-..	CI var referenced t..	Info	infra-pipelines	a4c9c77	.github/workflows/b..	72-80 Secret ref n..
MCAP-SEC-7426	python.tests.mock-..	Safe mock usage i..	Info	risk-analytics	99e0b1e	tests/unit/test_mod..	54-67 Patch applie..
MCAP-SEC-7427	go.errors.wrap	Error wrapping con..	Info	api-gateway-go	2c3e897	pkg/handlers/ping...	33-40 fmt.Errorf wr..
MCAP-SEC-7428	java.logging.place..	Placeholder alignm..	Info	treasury-ops	6d77f94	src/main/java/io/m..	88-96 Placeholder ..
MCAP-SEC-7429	ts.react.key-prop	React list key pres..	Info	client-portal	dd90a11	src/components/R..	19-30 Key prop us..
MCAP-SEC-7430	python.logging.saf..	Logging interpolati..	Info	risk-analytics	712f33a	analytics/runner.py	145-156 Parametri..
MCAP-SEC-7431	cs.async.await-all	Await pattern consi..	Info	ops-dashboard	39a2be0	Controllers/Status..	64-78 Await inside ..
MCAP-SEC-7432	java.streams.collec..	Stream collector c..	Info	treasury-ops	a1e9b74	src/main/java/io/m..	231-239 Collector t..
MCAP-SEC-7433	python.type-hints.p..	Type hints present	Info	api-gateway	e7d2e10	services/routing/m..	17-28 Typed signa..
MCAP-SEC-7434	js.promise.catch	Promise chain ter..	Info	client-portal	8f0b1d9	src/api/fetcher.ts	101-114 Catch pre..
MCAP-SEC-7435	terraform.var.outpu..	Output references ..	Info	infra-pipelines	5ce4b10	terraform/env/prod/..	9-20 Scoped outpu..
MCAP-SEC-7436	sql.query.param-st..	Parameter style co..	Info	data-services	a9c44e3	queries/reports/mo..	1-18 Named para..
MCAP-SEC-7437	kotlin.nullability.an..	Nullability annotati..	Info	mobile-banking	0e7a9df	app/src/main/kotlin..	45-57 @Nullable/..
MCAP-SEC-7438	python.dataclass.u..	Dataclass used for..	Info	api-gateway	ccdef01	services/models/dt..	6-19 @dataclass w..
MCAP-SEC-7439	java.records.dto	Records used for ..	Info	treasury-ops	61f2e9a	src/main/java/io/m..	1-12 Java record T..
MCAP-SEC-7440	js.eslint.no-console..	Console avoided; l..	Info	client-portal	7b2cfe1	src/utils/notify.ts	73-86 Logger wrap..
MCAP-SEC-7441	python.import.order	Import order consi..	Info	risk-analytics	2139bdc	analytics/lib/io.py	1-14 isort-style gro..
MCAP-SEC-7442	ruby.rubocop.freez..	Constants frozen	Info	payout-service	5f11be0	lib/payouts/consta..	3-10 Freeze literal ..
MCAP-SEC-7443	dockerfile.user.nob..	Non-root user confi..	Info	api-gateway	c2a9a10	docker/Dockerfile	21-33 USER app P..
MCAP-SEC-7444	helm.values.sche..	Values schema pr..	Info	infra-pipelines	14a93e2	charts/gateway/val..	1-40 Schema cont..

SAST Rule Coverage and Execution Metrics (Sprint 42)

Component	Repo	Scan ID	Rules Executed	Files Scanned	LOC Scanned	Matches (Security)	Matches (Info) Tri..
Client Portal (Web)	client-portal	build-42.17	1,284	1,146	178,234	0	37 37 1 3 34 02:11..
API Gateway (Pyth..	api-gateway	build-42.11	1,198	742	121,509	0	29 29 0 2 27 01:56..
Treasury Ops (Jav..	treasury-ops	build-42.09	1,422	913	204,118	0	31 31 2 4 27 02:23..
Risk Analytics (Py)	risk-analytics	build-42.05	1,036	518	97,003	0	24 24 0 1 23 01:47..
Data Services (SQ..	data-services	build-42.04	612	209	41,882	0	12 12 0 0 12 01:05..
Ops Dashboard (C..	ops-dashboard	build-42.06	884	331	58,771	0	16 16 1 1 14 01:19..
Payout Service (R..	payout-service	build-42.03	711	167	29,441	0	9 9 0 1 8 00:54 Ye..
Mobile Banking (K..	mobile-banking	build-42.10	932	488	83,665	0	18 18 0 2 16 01:28..
Infra Pipelines	infra-pipelines	build-42.08	563	124	15,739	0	11 11 0 3 8 00:49 ..
API Gateway (Go)	api-gateway-go	build-42.02	674	205	36,118	0	13 13 0 0 13 01:02..

Suppressions and Allowlist Items Renewed (Non-Security Operational)

Allowlist ID	Scope	Rule ID	Rationale	Owner	Renewal Date	Next Review	Status Related Ti..

AWL-2025-0041	tests/**	generic.best-practi..	Applies to test-only..	AppSec Engineeri..	2026-07-12	2027-01-12	Active MCAP-SEC..
AWL-2025-0042	scripts/dev/**	python.style.f-strin..	Dev tooling only, st..	Platform Security	2026-07-12	2027-01-12	Active MCAP-SEC..
AWL-2025-0043	charts/**	helm.values.sche..	Helm schema flag..	Enterprise DevOps	2026-07-15	2027-01-15	Active MCAP-SEC..
AWL-2025-0044	docker/**	dockerfile.user.nob..	Affirmative check r..	Platform Security	2026-07-15	2027-01-15	Active MCAP-SEC..
AWL-2025-0045	queries/**	sql.query.param-st..	Informational only	Data Services	2026-07-14	2027-01-14	Active MCAP-SEC..

Notes:

- All entries above are informational or best-practice confirmations retained for continuous compliance telemetry.
- No policy exceptions were requested or approved in Sprint 42.
- Review SLAs were met across all backlogs; no carryover items require escalation into Sprint 43.

SAST/DAST Security Scan Report -- Sprint 42 -- Meridian Capital

Page 24 -- DAST Coverage, Header Observations, and Cross-Validation

The DAST execution for Sprint 42 targeted non-production environments with authenticated and unauthenticated flows. Crawler coverage, request volumes, and session stability remained within operational norms. No exploitable behaviors were observed during auditing; responses complied with platform controls. The following tables summarize coverage statistics, security header observations, cross-tool concordance, and queue aging trends.

DAST Crawl and Audit Coverage -- Sprint 42

Target	Environment	Scan ID	Start Time (UTC)	Duration	URLs Discovered	Forms Exercised	Auth Sessions A..
Client Portal	qa-web	dast-42.18	2026-07-13T02:15:..	02:43:12	1,284	219	6 100% 9,412 1,10..
API Gateway (RES..	qa-api	dast-42.15	2026-07-12T22:01:..	01:58:44	503	68	4 100% 6,781 432 ..
Treasury Ops Con..	qa-web	dast-42.14	2026-07-12T18:44:..	02:11:37	642	97	3 100% 5,002 355 ..
Risk Analytics UI	qa-web	dast-42.13	2026-07-12T15:29:..	01:36:23	421	55	2 100% 3,891 288 ..
Ops Dashboard	qa-web	dast-42.12	2026-07-12T12:10:..	01:21:10	337	41	2 100% 2,977 251 ..
Payout Service API	qa-api	dast-42.11	2026-07-12T09:02:..	01:09:56	289	33	2 100% 2,411 199 ..

Application Security Headers Observation Sample (Representative)

Target	Sample URL	HSTS	CSP	X-Frame-Options	X-Content-Type-..	Referrer-Policy	Permissions-Poli..
Client Portal	https://qa.mc-porta..	Present, max-age=..	Present; restrictive..	DENY	nosniff	strict-origin-when-c..	Geolocation=() Ca..
API Gateway (RES..	https://qa.api.merid..	Present, max-age=..	Present; default-sr..	DENY	nosniff	no-referrer	InterestCohort=() S..
Treasury Ops Con..	https://qa.treasury...	Present, preload c..	Present; script-src ..	SAMEORIGIN	nosniff	same-origin	ClipboardRead=() ..
Risk Analytics UI	https://qa.risk.meri..	Present	Present; object-src..	DENY	nosniff	strict-origin	Geolocation=() Su..
Ops Dashboard	https://qa.ops.meri..	Present	Present; base-uri '..	DENY	nosniff	no-referrer-when-d..	Sensors=() Suppre..
Payout Service API	https://qa.pay.meri..	Present	N/A (API)	DENY	nosniff	same-origin	InterestCohort=() S..

Cross-Tool Concordance (Semgrep vs DAST) -- Benign Signals

Reference	Component	Semgrep Signal	DAST Observation	Correlation Result	Owner	Follow-up Ticket	Status Notes
XVAL-42-001	Client Portal	Logger usage style..	No anomalous res..	Concordant benign	Digital Channels	MCAP-SEC-7424	Closed Style-only ..
XVAL-42-002	API Gateway	Type hints/DTO co..	Normalized payloa..	Concordant benign	Platform Security	MCAP-SEC-7433	Closed No behavio..
XVAL-42-003	Treasury Ops	Placeholder alignm..	Stable log formatti..	Concordant benign	Treasury Tech	MCAP-SEC-7428	Closed No header ..
XVAL-42-004	Risk Analytics	Parametrized loggi..	No error leakage	Concordant benign	Quant Tech	MCAP-SEC-7430	Closed Expected r..
XVAL-42-005	Ops Dashboard	Async await patter..	No race artifacts	Concordant benign	Enterprise DevOps	MCAP-SEC-7431	Closed Latency wit..
XVAL-42-006	Payout Service	Constant immutabi..	Deterministic resp..	Concordant benign	Payments	MCAP-SEC-7442	Closed No state drift

Review Queue Aging -- Sprint 42 Close

Queue	Items Open (S41 ..	Items Ingested (S..	Items Closed (S42)	Mean Age Open (..	P90 Age (days)	Oldest Item	SLA Breaches Pri..
SAST -- Client Port..	1	37	38	0.6	1.1	MCAP-SEC-7339	0 Digital Channels
SAST -- API Gate..	0	29	29	0.5	0.9	--	0 Platform Security
SAST -- Treasury ..	2	31	33	0.7	1.3	MCAP-SEC-7301	0 Treasury Tech
SAST -- Risk Anal..	0	24	24	0.4	0.8	--	0 Quant Tech
SAST -- Shared S..	0	22	22	0.5	1.0	--	0 Enterprise DevO..
DAST -- Web Apps	0	17	17	0.6	1.2	--	0 AppSec Enginee..
DAST -- APIs	0	11	11	0.6	1.0	--	0 Platform Security

Operational Highlights:

- Authentication success rate remained at 100% across QA environments; session reuse operated within defined lifetimes.
- Header observations were consistent across targets; no deviations requiring remediation were recorded.
- All SAST/DAST queues met SLA; no items rolled into Sprint 43 for action.
- Metrics align with the previous sprint's baselines, with minor improvements in median review time for the API Gateway and Risk Analytics backlogs.

Page 25 -- Sprint 42 Close-Out, KPI Summary, and Audit Appendices

This page finalizes the Sprint 42 Semgrep SAST operational record for Meridian Capital. All scan activities completed on schedule, with routine informational and maintainability observations triaged and documented. No blocking items were encountered in the CI/CD flow, and all informational findings received review and disposition ahead of sprint closure. Metrics below reflect consistency of execution, rule-bundle freshness, and artefact governance. The audit trail provides traceability across pipelines, runners, and commits. Approvals and sign-offs confirm that required stakeholders reviewed outcomes and acknowledged the benign nature of recorded items.

KPI Summary -- Sprint 42 Execution

Metric ID	Description	Target	Actual	Delta	Status	Owner	Team Timestamp
KPI-4201	SAST coverage (a..	24	24	0	Met	A. Patel	AppSec Ops 2026-..
KPI-4202	Avg SAST job dura..	06:30	06:18	-00:12	Met	N. Romero	Dev Productivity 2..
KPI-4203	Informational FP ra..	<=10%	8.7%	-1.3 pp	Met	J. Lin	Quality Eng 2026-..
KPI-4204	Rule bundle freshn..	<=14	7	-7	Met	K. Huang	AppSec Eng 2026-..
KPI-4205	Cross-checks logg..	10	12	+2	Met	P. O'Connor	Security Eng 2026-..
KPI-4206	Benign/information..	100%	100%	0	Met	R. Singh	Platform Sec 2026..
KPI-4207	Auto-tagging accur..	>=95%	96.4%	+1.4 pp	Met	T. Becker	DevOps Tooling 2..
KPI-4208	Scan queue SLA b..	0	0	0	Met	L. Stewart	CI Orchestration 2..
KPI-4209	CI job success rate..	>=99%	99.6%	+0.6 pp	Met	C. Mendes	Release Eng 2026..
KPI-4210	Artefact retention c..	100%	100%	0	Met	D. Alvarez	Compliance Ops 2..

Issue Disposition Register (Informational/Maintainability Only)

Ticket	Repo	Rule ID	Title	Severity	Disposition	Rationale	Team Reviewed B..
SEC-74201	mc-ledger	MC.RULE.LOGGI..	Log field formatting	Informational	Benign -- Style/Ex..	Conforms to loggin..	Core Banking S. O..
SEC-74202	treasury-api	MC.RULE.STYLE.I..	Import order stand..	Informational	Benign -- Style/Ex..	Managed by linter; ..	Treasury Tech M. ..
SEC-74203	wealth-portal	MC.RULE.MAINT..	Unreferenced priva..	Low	Benign -- Deferred ..	Tracked in backlog..	Wealth Digital M. ..
SEC-74204	risk-analytics	MC.RULE.TEST.N..	Test method nami..	Informational	Not Applicable	Third-party tests; e..	Risk Analytics M. ..
SEC-74205	mc-ledger	MC.RULE.API.DOC	Missing API doc co..	Informational	Benign -- Docume..	Tracked via docs ..	Core Banking M. G..
SEC-74206	data-pipeline	MC.RULE.CONFI..	Inline comment in ..	Informational	Benign -- Expected	Internal annotation..	Data Eng M. Nova..
SEC-74207	treasury-api	MC.RULE.NULLS..	Optional null-safe ..	Informational	Duplicate (auto-opt..	Handled by compil..	Treasury Tech H. ..
SEC-74208	wealth-portal	MC.RULE.SERIAL..	Serializable with e..	Informational	Benign -- Standard..	Meets internal guid..	Wealth Digital K. M..
SEC-74209	risk-analytics	MC.RULE.STRICT..	Use strict equality ..	Informational	Benign -- Style/Ex..	Pattern preferred; ..	Risk Analytics P. S..
SEC-74210	data-pipeline	MC.RULE.ERROR..	Wrap low-level exc..	Informational	Benign -- Consiste..	Aligns with service ..	Data Eng L. Kim 2..

Semgrep Job Audit Trail -- Sprint 42 Runs

Job ID	Pipeline	Runner	Commit SHA	Branch	Start	End	Duration Exit Cod..
MC-SAST-42-0010	mc-ledger-main	mc-ci-runner-07	a9f1c3e77b1a48f5..	main	2026-07-20T09:01:..	2026-07-20T09:07:..	00:06:17 0 semgre..
MC-SAST-42-0011	treasury-api-release	mc-ci-runner-03	4b6e2a9d2f3c4e5..	release/3.8	2026-07-20T10:13:..	2026-07-20T10:19:..	00:06:36 0 semgre..
MC-SAST-42-0012	wealth-portal-pr-18..	mc-ci-runner-02	c1d2e3f4a5b6c7d8..	feature/ui-tune	2026-07-20T12:21:..	2026-07-20T12:28:..	00:06:12 0 semgre..
MC-SAST-42-0013	risk-analytics-main	mc-ci-runner-05	0f1e2d3c4b5a697..	main	2026-07-20T14:45:..	2026-07-20T14:51:..	00:06:29 0 semgre..
MC-SAST-42-0014	data-pipeline-nightly	mc-ci-runner-06	112233445566778..	nightly	2026-07-20T23:00:..	2026-07-20T23:06:..	00:06:48 0 semgre..
MC-SAST-42-0015	mc-ledger-pr-592	mc-ci-runner-07	223344556677889..	PR/592	2026-07-21T08:17:..	2026-07-21T08:23:..	00:06:15 0 semgre..
MC-SAST-42-0016	treasury-api-main	mc-ci-runner-03	33445566778899a..	main	2026-07-21T11:09:..	2026-07-21T11:15:..	00:06:30 0 semgre..
MC-SAST-42-0017	wealth-portal-relea..	mc-ci-runner-02	445566778899aab..	release/2.4	2026-07-21T13:33:..	2026-07-21T13:39:..	00:06:33 0 semgre..
MC-SAST-42-0018	risk-analytics-pr-901	mc-ci-runner-05	5566778899aabbc..	PR/901	2026-07-21T15:52:..	2026-07-21T15:58:..	00:06:11 0 semgre..
MC-SAST-42-0019	data-pipeline-main	mc-ci-runner-06	66778899aabbccd..	main	2026-07-21T20:10:..	2026-07-21T20:16:..	00:06:26 0 semgre..

Artefact Inventory -- Storage and Retention

Artefact ID	Type	Location	Retention	Hash (SHA256, s..	Size	Created	Expires Owner N..
ART-42-0001	report.json	s3://sec-reports/sp..	90d	7ab3c91f0d2a	1.8 MB	2026-07-20T09:08:..	2026-10-18T09:08:..
ART-42-0002	findings.csv	s3://sec-reports/sp..	90d	1c9eab5527e4	512 KB	2026-07-20T10:20:..	2026-10-18T10:20:..
ART-42-0003	sarif	s3://sec-reports/sp..	90d	54d1aa09fe8b	2.3 MB	2026-07-20T12:28:..	2026-10-18T12:28:..
ART-42-0004	logs	s3://sec-logs/ci/20..	30d	b8a4de117a22	4.1 MB	2026-07-20T14:52:..	2026-08-19T14:52:..
ART-42-0005	metrics.json	s3://sec-metrics/sp..	365d	2ff0a8c43dc0	96 KB	2026-07-22T18:10:..	2027-07-22T18:10:..
ART-42-0006	trace.zip	s3://sec-traces/risk..	30d	0a19be7712c8	8.7 MB	2026-07-21T15:59:..	2026-08-20T15:59:..
ART-42-0007	report.json	s3://sec-reports/sp..	90d	6c77c0d3be55	1.5 MB	2026-07-21T20:17:..	2026-10-19T20:17:..
ART-42-0008	index.html	s3://sec-dashboard..	180d	3e2b1144a9f1	72 KB	2026-07-22T09:30:..	2027-01-18T09:30:..
ART-42-0009	summary.pdf	s3://sec-reports/sp..	365d	d1f55aa6b0cc	384 KB	2026-07-22T18:12:..	2027-07-22T18:12:..
ART-42-0010	manifest	s3://sec-reports/sp..	365d	9e774a10c4e3	12 KB	2026-07-22T18:13:..	2027-07-22T18:13:..

Approvals and Sign-Offs -- Sprint Closure

Checklist ID	Item	Status	Approver	Team	Timestamp	Reference	Comments
CLS-42-001	SAST job completi..	Approved	V. Reynolds	Release Eng	2026-07-22T18:20:..	REL-10294	All SAST stages gr..
CLS-42-002	Rule-bundle verific..	Approved	E. Morin	AppSec Eng	2026-07-22T14:05:..	SEC-RB-773	semgrep-meridian-..
CLS-42-003	Informational findin..	Approved	H. Whitaker	Platform Sec	2026-07-22T17:22:..	SEC-74200	Benign/maintainabi..
CLS-42-004	Artefact retention/..	Approved	C. Delgado	Compliance Ops	2026-07-22T18:14:..	CMP-4412	Retention windows..
CLS-42-005	CI runner health st..	Recorded	J. Park	CI Orchestration	2026-07-22T11:12:..	CIOPS-2207	No capacity incide..
CLS-42-006	KPI threshold asse..	Approved	R. Bennett	Quality Eng	2026-07-22T18:11:..	QA-PT-8821	Targets met; varia..
CLS-42-007	Cross-check with ..	Accepted	P. O'Connor	Security Eng	2026-07-22T16:40:..	DAST-ALN-139	Cross-references c..
CLS-42-008	Repository inclusio..	Approved	G. Alvarez	DevOps Tooling	2026-07-22T10:01:..	DEVOPS-6154	24 repos scanned t..
CLS-42-009	Stakeholder distrib..	Recorded	N. Patel	Sec PMO	2026-07-22T18:25:..	PMO-3365	Distribution list ack..
CLS-42-010	Sprint 42 SAST/D..	Approved	L. Matthews	Security GRC	2026-07-22T18:26:..	GRC-2026-07	Final sign-off; archi..

End of document -- SAST/DAST Security Scan Report -- Sprint 42 for Meridian Capital.